

Proyecto 2 - Sistema de Logging con ELK Stack

Pablo Andrés Zamora Vásquez - 21780

Diego Andrés Morales Aquino - 21762

Erick Stiv Junior Guerra - 21781

Fecha: 25/11/2025

Índice

1.

Resumen Ejecutivo
2.

Paso 1: Juice Shop Básico
3.

Paso 2: Elasticsearch
4.

Paso 3: Kibana
5.

Paso 4: Filebeat
6.

Paso 5: Visualización en Kibana
7.

Paso 6: Blue Team & Red Team
8.

Análisis Técnico
9.

Problemas y Soluciones
10.

Conclusiones

Resumen Ejecutivo

Descripción del Proyecto

[Describe en 2-3 párrafos qué es el proyecto, qué tecnologías usaste y qué lograste]

Objetivos Cumplidos

- Sistema ELK Stack completamente funcional
- Logs recolectándose en tiempo real
- Visualizaciones y dashboards creados
- 3 reglas de detección configuradas
- 4 vulnerabilidades explotadas y documentadas

Tecnologías Utilizadas

- Docker y Docker Compose
- OWASP Juice Shop
- Elasticsearch 8.11.0
- Kibana 8.11.0
- Filebeat 8.11.0

Tiempo Invertido

Paso	Tiempo Real
------	-------------

Paso	Tiempo Real
Paso 1: Juice Shop	15 min
Paso 2: Elasticsearch	10 min
Paso 3: Kibana	15 min
Paso 4: Filebeat	10 min
Paso 5: Visualización	20 min
Paso 6: Blue/Red Team	240 min
Documentación	60 min
TOTAL	6.16 horas

Paso 1: Juice Shop Básico

Objetivo

Levantar el código Javascript del proyecto Juice Shop de OWASP mediante un contenedor de Docker.

Comandos Ejecutados

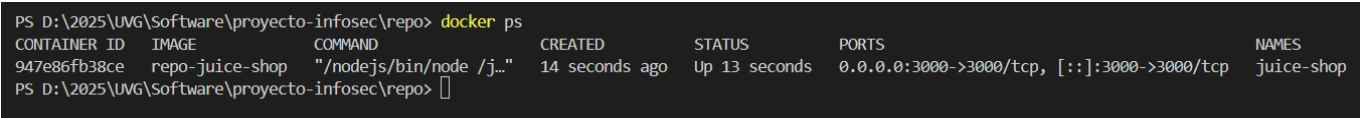
Comando 1
docker compose up -d

Comando 2
docker compose ps

[Continúa con todos los comandos...]

Screenshots

Screenshot 1.1: Docker Compose PS

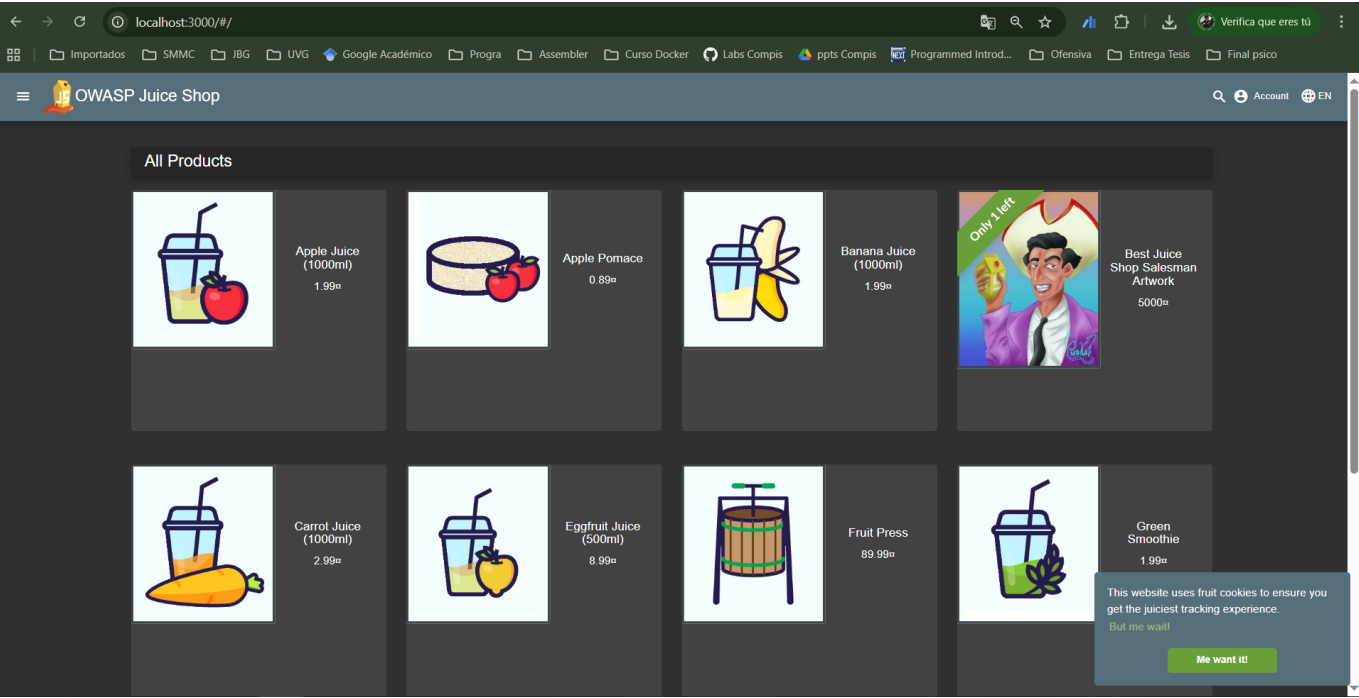


Descripción: Estado del contenedor "juice-shop" en Docker

Verificación:

- ☒ Contenedor en estado "Up"
- ☒ Sin errores

Screenshot 1.2: Navegador en http://localhost:3000

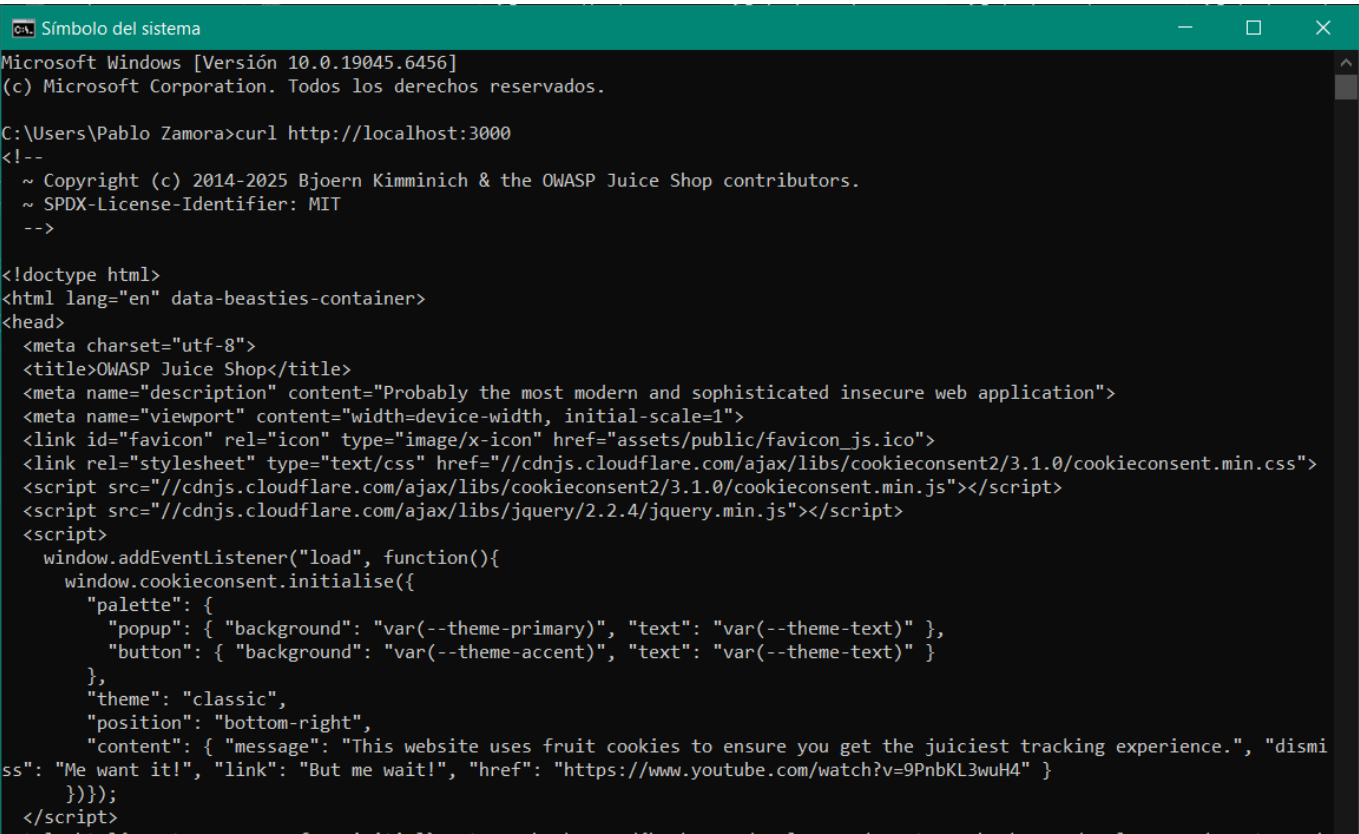


Descripción: Interfaz de usuario de Juice Shop al acceder a localhost:3000

Verificación:

- ☒ Interfaz renderiza correctamente

Screenshot 1.3: Terminal con curl http://localhost:3000



Descripción: CURL realizado a localhost en el puerto sobre el que se está ejecutando Juice Shop

Verificación:

- ☒ CURL devuelve el HTML esperado

Screenshot 1.4: Terminal con logs

```

• PS D:\2025\UVG\Software\proyecto-infosec\repo> docker compose logs juice-shop
juice-shop | WARNING: NODE_ENV value of 'production' did not match any deployment config file names.
juice-shop | WARNING: See https://github.com/node-config/node-config/wiki/Strict-Mode
juice-shop | info: Detected Node.js version v22.18.0 (OK)
juice-shop | info: Detected OS linux (OK)
juice-shop | info: Detected CPU x64 (OK)
juice-shop | info: Configuration production validated (OK)
juice-shop | info: Entity models 20 of 20 are initialized (OK)
juice-shop | info: Required file server.js is present (OK)
juice-shop | info: Required file index.html is present (OK)
juice-shop | info: Required file runtime.js is present (OK)
juice-shop | info: Required file tutorial.js is present (OK)
juice-shop | info: Required file styles.css is present (OK)
juice-shop | info: Required file vendor.js is present (OK)
juice-shop | info: Required file main.js is present (OK)
juice-shop | info: Port 3000 is available (OK)
juice-shop | info: Chatbot training data botDefaultTrainingData.json validated (OK)
juice-shop | info: Domain https://www.alchemy.com/ is reachable (OK)
juice-shop | info: Server listening on port 3000
• PS D:\2025\UVG\Software\proyecto-infosec\repo>

```

Descripción: Logs del contenedor de Docker

Verificación:

- ☒ Log de servidor ejecutándose correctamente en el puerto 3000
- ☒ Sin errores

Verificación de Éxito

- ☒ Contenedor corriendo sin errores
- ☒ Puerto 3000 accesible
- ☒ Interfaz web funcional
- ☒ Logs generándose
- ☒ 4 screenshots capturados

Conceptos Aprendidos

1. **Docker Compose:** [Explica qué aprendiste]
2. **Port Mapping:** [Explica qué aprendiste]
3. **Container Logs:** [Explica qué aprendiste]

Paso 2: Elasticsearch

Objetivo

Agregar Elasticsearch como motor de almacenamiento de logs.

Comandos Ejecutados

Comando 1
 docker compose up -d

Comando 2
 docker compose ps

Comando 3
 curl http://localhost:9200/_cluster/health?pretty

Comando 4
 curl http://localhost:9200

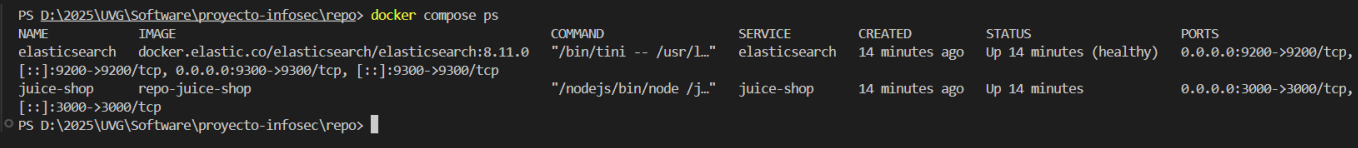
Comando 5
 curl -X POST "http://localhost:9200/test-index/_doc" \
 -H 'Content-Type: application/json' \
 -d '{
 "message": "Test log entry",
 "timestamp": "2025-11-04T10:00:00Z"
 }'

Comando 6
 curl "http://localhost:9200/test-index/_search?pretty"

Comando 7
 curl "http://localhost:9200/_cat/indices?v"

Screenshots

Screenshot 2.1: Docker Compose PS

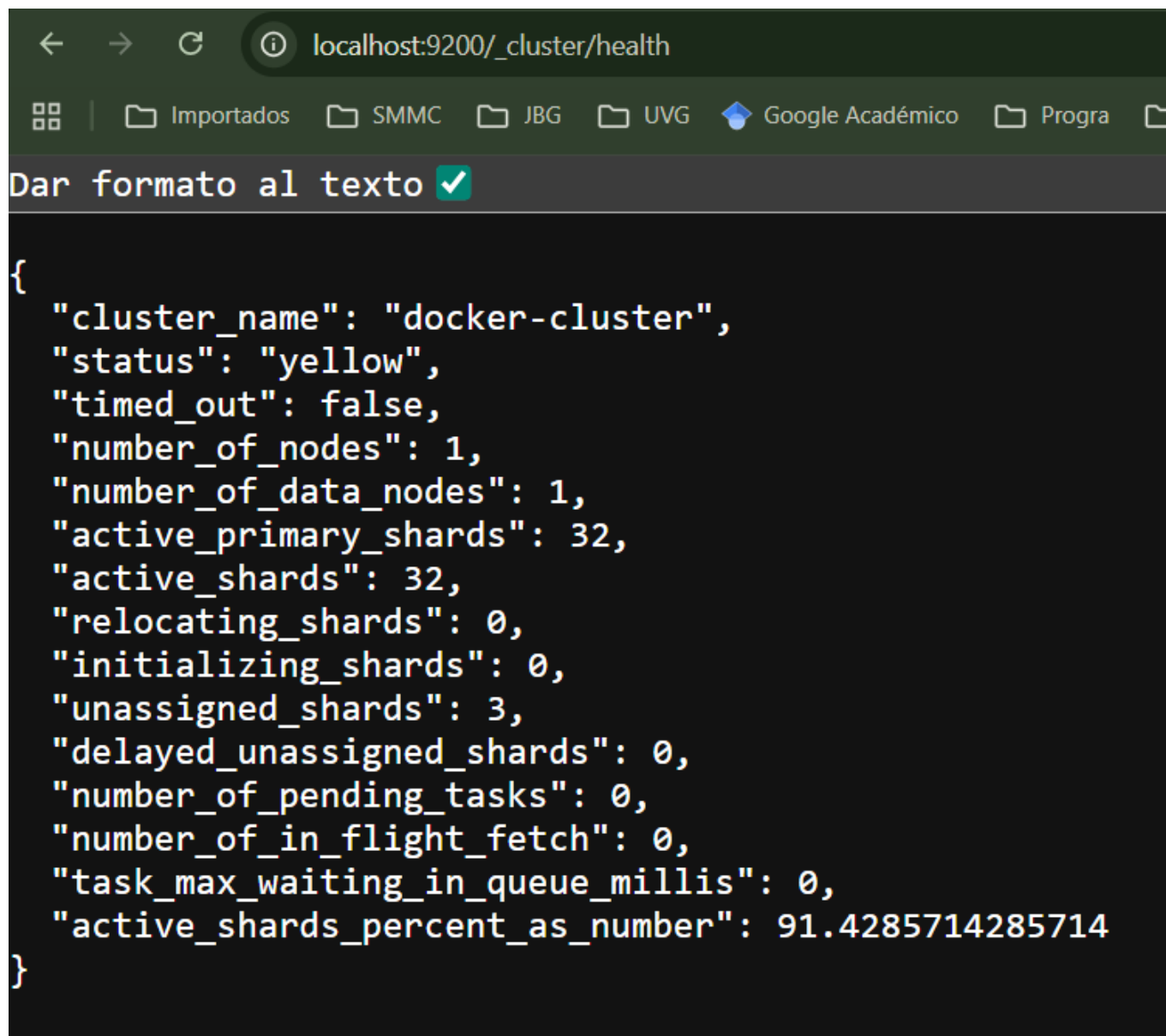


Descripción: Estado del contenedor "elasticsearch" en Docker

Verificación:

- ☒ Estado del contenedor de ElasticSearch "healthy"

Screenshot 2.2: Salud del cluster



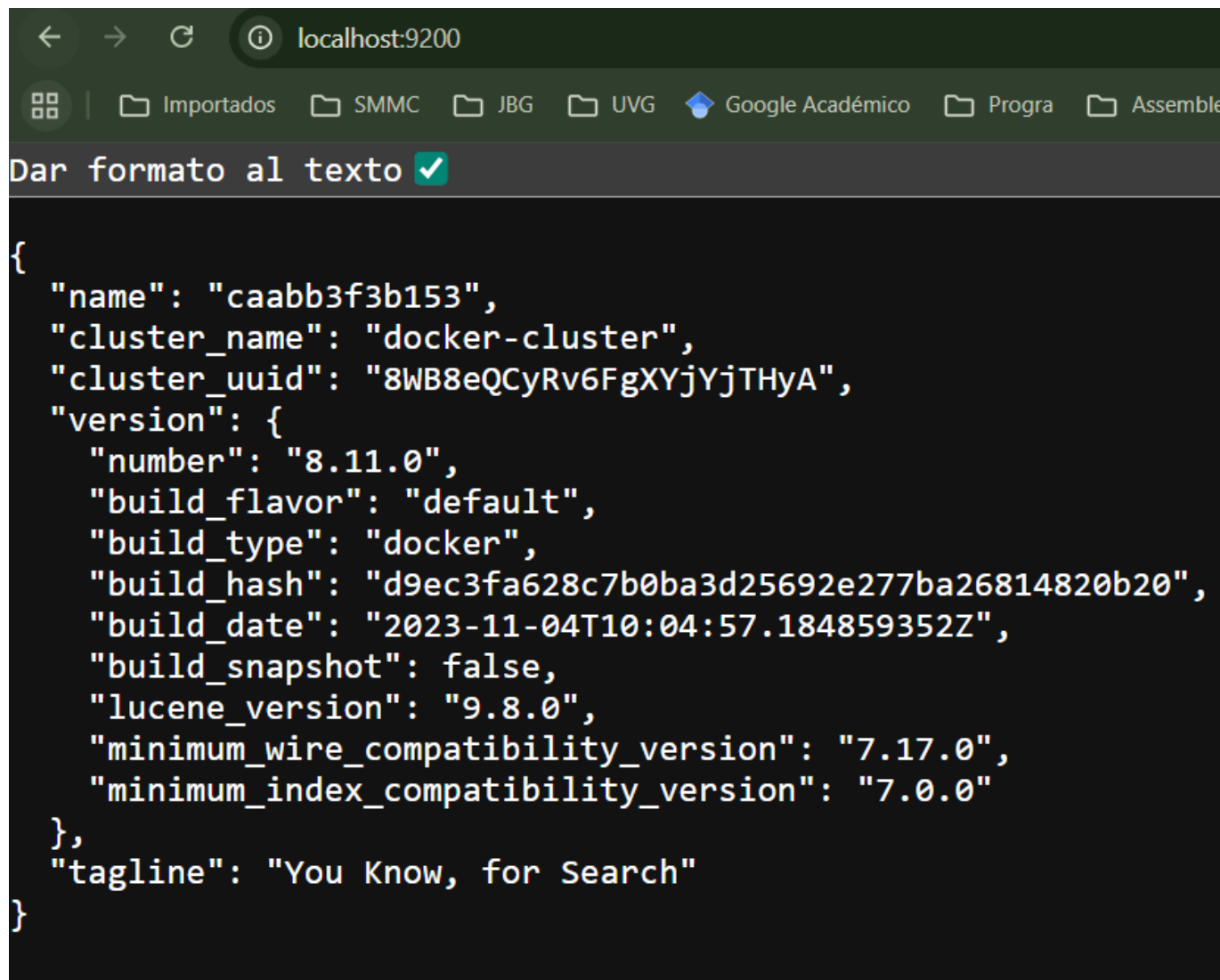
```
{
  "cluster_name": "docker-cluster",
  "status": "yellow",
  "timed_out": false,
  "number_of_nodes": 1,
  "number_of_data_nodes": 1,
  "active_primary_shards": 32,
  "active_shards": 32,
  "relocating_shards": 0,
  "initializing_shards": 0,
  "unassigned_shards": 3,
  "delayed_unassigned_shards": 0,
  "number_of_pending_tasks": 0,
  "number_of_in_flight_fetch": 0,
  "task_max_waiting_in_queue_millis": 0,
  "active_shards_percent_as_number": 91.4285714285714
}
```

Descripción: Salud del Cluster

Verificación:

- ☒ Estado "Yellow"

Screenshot 2.3: Información del nodo



```
{
  "name": "caabb3f3b153",
  "cluster_name": "docker-cluster",
  "cluster_uuid": "8WB8eQCyRv6FgXYjYjTHyA",
  "version": {
    "number": "8.11.0",
    "build_flavor": "default",
    "build_type": "docker",
    "build_hash": "d9ec3fa628c7b0ba3d25692e277ba26814820b20",
    "build_date": "2023-11-04T10:04:57.184859352Z",
    "build_snapshot": false,
    "lucene_version": "9.8.0",
    "minimum_wire_compatibility_version": "7.17.0",
    "minimum_index_compatibility_version": "7.0.0"
  },
  "tagline": "You Know, for Search"
}
```

Descripción: Información del nodo de Elasticsearch

Verificación:

- ☒ Puerto 9200 respondiendo

Screenshot 2.4: Creación de documento

POST ⌵ http://localhost:9200/test-index/_doc

Docs Params Authorization Headers (10) **Body** • Scripts Tests Settings

☐ none ☐ form-data ☐ x-www-form-urlencoded ☒ raw ☐ binary ☐ GraphQL **JSON** ⌵

```

1  {
2    "message": "Test log entry",
3    "timestamp": "2025-11-04T10:00:00Z"
4  }

```

Body Cookies Headers (5) Test Results ↺

{} JSON ⌵ ▶ Preview 🖼️ Visualize ⌵

```

1  {
2    "_index": "test-index",
3    "_id": "Z-fEpZoBkgWapsG4K0cN",
4    "_version": 1,
5    "result": "created",
6    "_shards": {
7      "total": 2,
8      "successful": 1,
9      "failed": 0
10   },
11   "_seq_no": 0,
12   "_primary_term": 1
13 }

```

← → ↻ ⓘ localhost:9200/test-index/_search

🗑️ Importados 📁 SMMC 📁 JBG 📁 UVG 📁 Google Académico

Dar formato al texto ✓

```

{
  "took": 16,
  "timed_out": false,
  "_shards": {
    "total": 1,
    "successful": 1,
    "skipped": 0,
    "failed": 0
  },
  "hits": {

```

```

    "total": {
      "value": 1,
      "relation": "eq"
    },
    "max_score": 1,
    "hits": [
      {
        "_index": "test-index",
        "_id": "Z-fEpZoBkgWapsG4K0cN",
        "_score": 1,
        "_source": {
          "message": "Test log entry",
          "timestamp": "2025-11-04T10:00:00Z"
        }
      }
    ]
  }
}

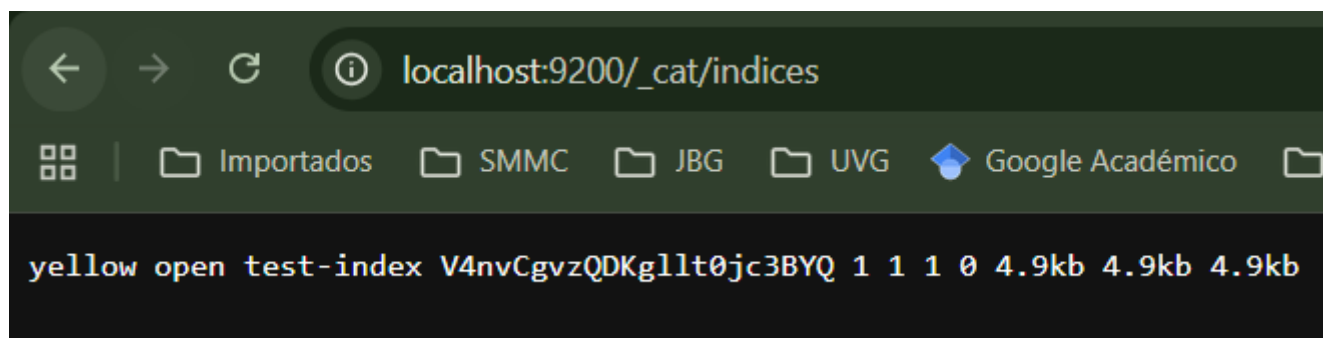
```

Descripción: Creación de un documento en un índice de prueba

Verificación:

- ☒ Creación exitosa del documento
- ☒ Respuesta del documento creado al buscarlo

Screenshot 2.5: Lista de índices



Descripción: Lista de índices en ElasticSearch

Verificación:

- ☒ Índice de prueba "test-index" listado

Verificación de Éxito

- ☒ Elasticsearch corriendo y healthy
- ☒ Cluster en estado GREEN/YELLOW
- ☒ Puerto 9200 respondiendo
- ☒ Puede crear documentos
- ☒ 5 screenshots capturados

Conceptos Aprendidos

1. **Elasticsearch:** [Explica]
2. **Índices y Documentos:** [Explica]
3. **RESTful API:** [Explica]

Paso 3: Kibana

Objetivo

Agregar Kibana como interfaz visual para Elasticsearch.

Comandos Ejecutados

Comando 1
 docker compose up -d

Comando 2
 docker compose ps

Comando 3
 curl http://localhost:5601/api/status | jq .

Screenshots

Screenshot 3.1: docker compose ps con los 3 servicios

PS D:\2025\UWG\Software\proyecto-infosec\repo> docker compose ps

NAME	IMAGE	COMMAND	SERVICE	CREATED	STATUS	PORTS
elasticsearch	docker.elastic.co/elasticsearch/elasticsearch:8.11.0	"/bin/tini -- /usr/l..."	elasticsearch	About an hour ago	Up 8 minutes (healthy)	0.0.0.0:9200->9200/tcp
juice-shop	repo-juice-shop	"/nodejs/bin/node /j..."	juice-shop	About an hour ago	Up 8 minutes	0.0.0.0:3000->3000/tcp
kibana	docker.elastic.co/kibana/kibana:8.11.0	"/bin/tini -- /usr/l..."	kibana	8 minutes ago	Up 7 minutes (healthy)	0.0.0.0:5601->5601/tcp

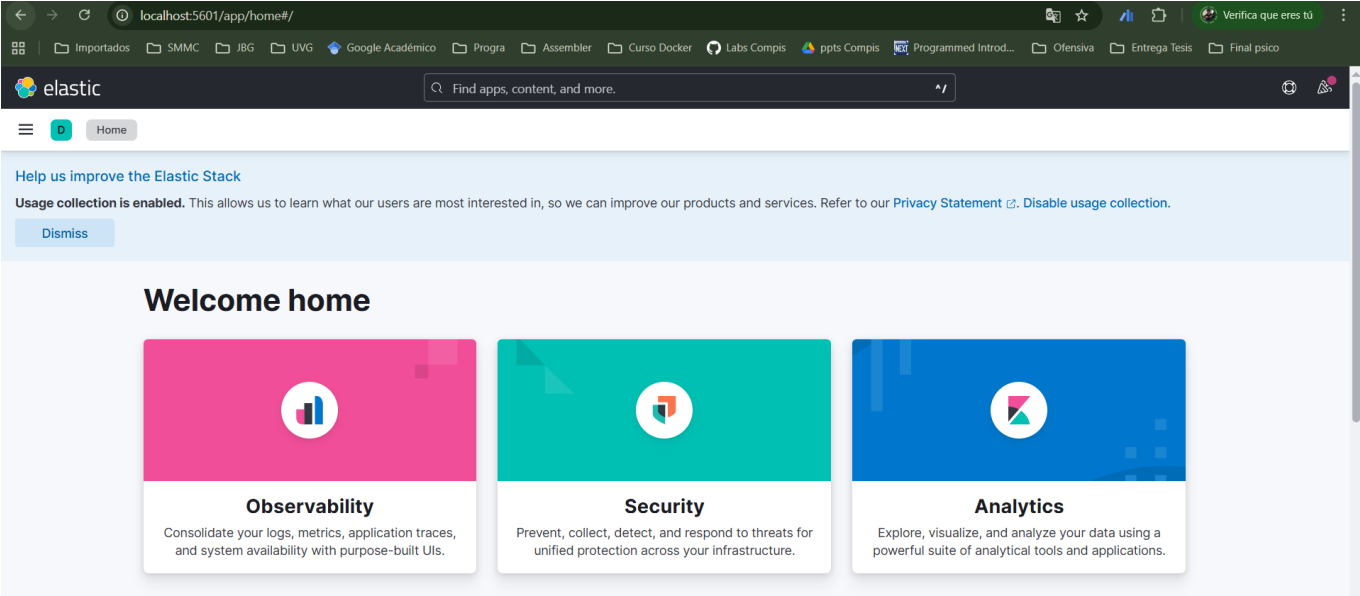
PS D:\2025\UWG\Software\proyecto-infosec\repo>

Descripción: Estado del contenedor "kibana" en Docker

Verificación:

- ☒ Estado del contenedor de Kibana "healthy"

Screenshot 3.2: Pantalla de bienvenida de Kibana

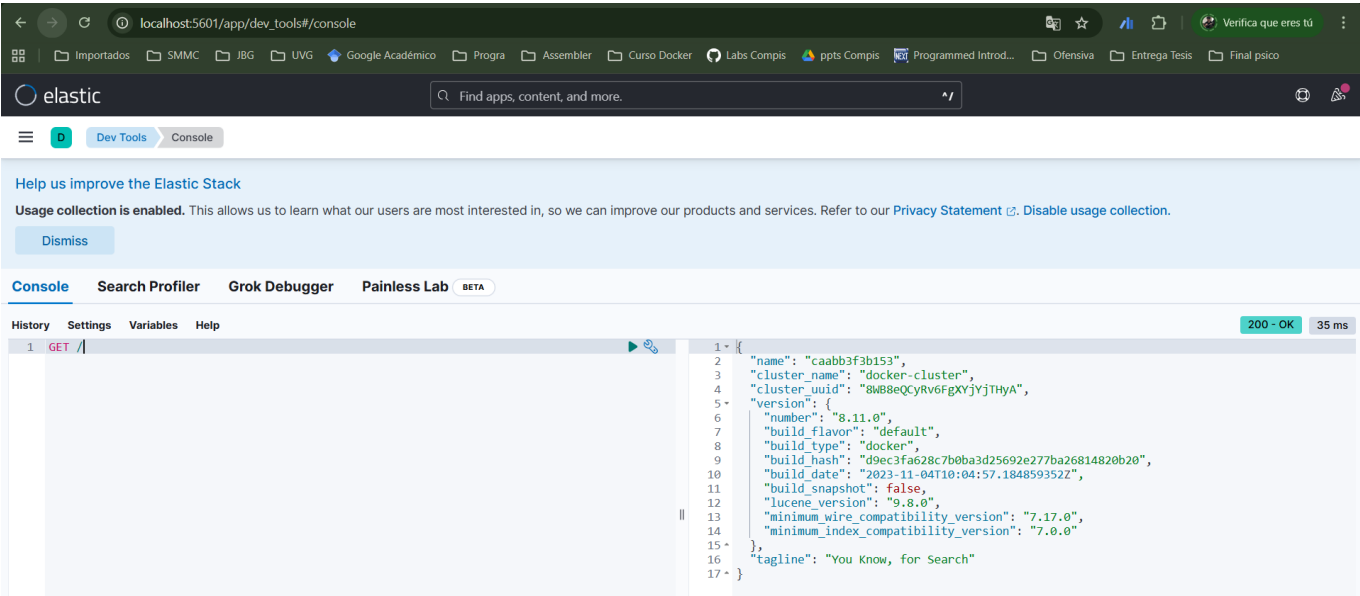


Descripción: Pantalla de bienvenida de la interfaz de Kibana en localhost:5601

Verificación:

- ☒ Puerto 5601 accesible
- ☒ Interfaz web funcional

Screenshot 3.3: Dev Tools con query GET / y respuesta

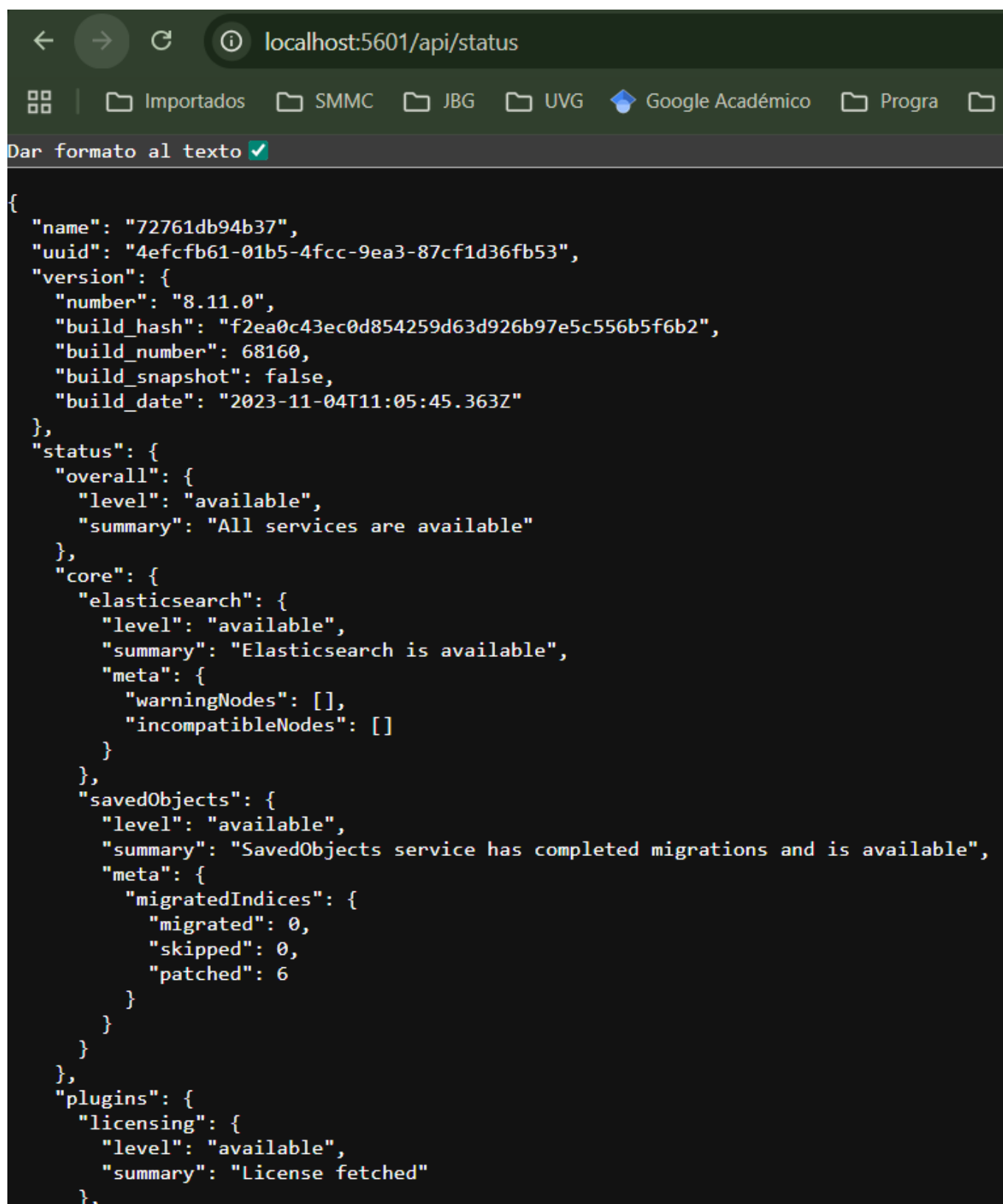


Descripción: Funcionamiento de las Dev Tools en la interfaz

Verificación:

- ☒ DevTools funcionando correctamente
- ☒ Respuesta correcta de GET /

Screenshot 3.4: Estado de Kibana



Descripción: Respuesta del endpoint /api/status de Kibana

Verificación:

- ☒ Estado "available"

Verificación de Éxito

- ☒ Kibana corriendo y healthy
- ☒ Puerto 5601 accesible
- ☒ Conectado a Elasticsearch
- ☒ Dev Tools funcional
- ☒ 4 screenshots capturados

Conceptos Aprendidos

1. **Kibana**: [Explica]
2. **Dev Tools**: [Explica]
3. **Redes Docker**: [Explica]

Paso 4: Filebeat

Objetivo

Agregar Filebeat para conectar todo el flujo de datos.

Comandos Ejecutados

```
# Comando 1
docker compose up -d
```

```
# Comando 2
docker compose ps
```

```
# Comando 3
docker compose logs filebeat | grep -i "connection"
```

```
# Comando 4
for i in {1..20}; do
  curl -s http://localhost:3000 > /dev/null
  echo "Request $i"
  sleep 1
done

```bash
Comando 5
curl "http://localhost:9200/_cat/indices?v" | grep filebeat
```

```

Comando 6
curl -X GET "http://localhost:9200/filebeat-juice-shop-*/_search?size=1&pretty"

```

Screenshots

Screenshot 4.1: docker compose ps con los 4 servicios

```

PS D:\2025\UWG\Software\proyecto-infosec\repo> docker compose ps
NAME IMAGE COMMAND SERVICE CREATED STATUS PORTS
elasticsearch docker.elastic.co/elasticsearch:8.11.0 "/bin/tini -- /usr/l..." elasticsearch 2 hours ago Up 41 minutes (healthy) 0.0.0.0:9200->9200/tcp,
filebeat docker.elastic.co/beats/filebeat:8.11.0 "/usr/bin/tini -- /u..." filebeat 16 seconds ago Up 14 seconds 0.0.0.0:3000->3000/tcp,
juice-shop repo-juice-shop "/nodejs/bin/node /j..." juice-shop 2 hours ago Up 41 minutes 0.0.0.0:5601->5601/tcp,
kibana docker.elastic.co/kibana/kibana:8.11.0 "/bin/tini -- /usr/l..." kibana 41 minutes ago Up 40 minutes (healthy) 0.0.0.0:5601->5601/tcp,

```

Descripción: Estado del conetendor "filebeat" en docker

Verificación:

- ☒ Contenedor ejecutándose

Screenshot 4.2: Logs de Filebeat mostrando conexión

```

PS D:\2025\UWG\Software\proyecto-infosec\repo> docker compose logs filebeat | findstr /i "connection"
filebeat | {"log.level":"info","@timestamp":"2025-11-21T10:47:41.318Z","log.logger":"esclientleg","log.origin":{"file.name":"eslegclient/connection.go","file.line":122},"message":"elasticsearch url: http://elasticsearch:9200","service.name":"filebeat","ecs.version":"1.6.0"}
filebeat | {"log.level":"warn","@timestamp":"2025-11-21T10:47:45.257Z","log.logger":"add_cloud_metadata","log.origin":{"file.name":"add_cloud_metadata/provider_aws_ec2.go","file.line":91},"message":"error fetching EC2 Identity Document: operation error ec2imds: GetInstanceIdentityDocument, exceeded maximum number of attempts, 3, request send failed, Get \
http://169.254.169.254/latest/dynamic/instance-identity/document/: dial tcp 169.254.169.254:80: connect: connection refused.", "service.name":"filebeat","ecs.version":"1.6.0"}
filebeat | {"log.level":"info","@timestamp":"2025-11-21T10:49:07.003Z","log.logger":"esclientleg","log.origin":{"file.name":"eslegclient/connection.go","file.line":304},"message":"Attempting to connect to Elasticsearch version 8.11.0 (default)","service.name":"filebeat","ecs.version":"1.6.0"}
filebeat | {"log.level":"info","@timestamp":"2025-11-21T10:49:07.023Z","log.logger":"esclientleg","log.origin":{"file.name":"eslegclient/connection.go","file.line":304},"message":"Attempting to connect to Elasticsearch version 8.11.0 (default)","service.name":"filebeat","ecs.version":"1.6.0"}
filebeat | {"log.level":"info","@timestamp":"2025-11-21T10:49:07.176Z","log.logger":"publisher_pipeline_output","log.origin":{"file.name":"pipeline/client_worker.go","file.line":145},"message":"Connection to backoff(elasticsearch(http://elasticsearch:9200)) established","service.name":"filebeat","ecs.version":"1.6.0"}

```

Descripción: Logs de Filebeat

Verificación:

- ☒ Conexión con ElasticSearch establecida

Screenshot 4.3: Generación de tráfico (loop de curl)

```

PS D:\2025\UVG\Software\proyecto-infosec\repo> for ($i = 1; $i -le 20; $i++) {
>> curl.exe http://localhost:3000 > $null
>> Write-Host "Request $i"
>> Start-Sleep -Seconds 1
>> }

```

	% Total	% Received	% Xferd	Average Dload	Average Upload	Speed	Time Total	Time Spent	Time Left	Current Speed
Request 1	100	75002	100 75002	0	0	1171k	0	--:--:--	--:--:--	1181k
Request 2	100	75002	100 75002	0	0	953k	0	--:--:--	--:--:--	963k
Request 3	100	75002	100 75002	0	0	2122k	0	--:--:--	--:--:--	2154k
Request 4	100	75002	100 75002	0	0	1562k	0	--:--:--	--:--:--	1592k
Request 5	100	75002	100 75002	0	0	1658k	0	--:--:--	--:--:--	1627k

**Descripción:** Loop de solicitudes a localhost:3000 (Juice Shop) para generar tráfico

**Verificación:**

- ☒ Solicitudes enviadas exitosamente

Screenshot 4.4: Índices filebeat-\* creados

```

localhost:9200/_cat/indices

```

Index	Status	Type	Priority	Shards	Replicas	Size in bytes	Size in KB	Size in MB
filebeat-docker-2025.11.17	yellow	open		62	0	94.9kb	94.9kb	94.9kb
test-index	yellow	open		1	0	5.1kb	5.1kb	5.1kb
.ds-filebeat-8.11.0-2025.11.21-000001	yellow	open		0	0	227b	227b	227b
filebeat-docker-2025.11.20	yellow	open		71	0	98.4kb	98.4kb	98.4kb
filebeat-docker-2025.11.21	yellow	open		905	0	3.3mb	3.3mb	3.3mb
filebeat-juice-shop-2025.11.21	yellow	open		18	0	104.7kb	104.7kb	104.7kb

**Descripción:** Lista de índices tras el tráfico generado hacia Juice Shop

**Verificación:**

- ☒ Índices filebeat-\*

Screenshot 4.5: Documento de log completo (JSON)



The screenshot shows a web browser window with the address bar displaying `localhost:9200/filebeat-juice-shop-*/_search?size=1`. The browser's tab bar shows several tabs: 'Importados', 'SMMC', 'JBG', 'UVG', and 'Google Académico'. Below the address bar, there is a toolbar with a checkmark icon and the text 'Dar formato al texto'. The main content area displays a JSON response from a search engine, which is a single log entry from filebeat.

```
{
 "took": 2,
 "timed_out": false,
 "_shards": {
 "total": 1,
 "successful": 1,
 "skipped": 0,
 "failed": 0
 },
 "hits": {
 "total": {
 "value": 18,
 "relation": "eq"
 },
 "max_score": 1,
 "hits": [
 {
 "_index": "filebeat-juice-shop-2025.11.21",
 "_id": "vnwWppoBM_auPBQDb2VQ",
 "_score": 1,
 "_source": {
 "@timestamp": "2025-11-21T11:01:39.575Z",
 "agent": {
 "ephemeral_id": "5d72e424-da4e-42ac-b628-511e917f910e",
 "id": "7fc7a30c-41e4-4c16-832e-5db3446b05aa",
 "name": "ec9a5ea3ce20",
 "type": "filebeat",
 "version": "8.11.0"
 },
 "ecs": {
 "version": "8.0.0"
 },
 "host": {
 "ip": [
 "172.18.0.5"
],
 "mac": [
 "26-44-11-B9-97-46"
],
 "hostname": "ec9a5ea3ce20",
 "name": "ec9a5ea3ce20",
 "architecture": "x86_64",
 "os": {
 "type": "linux",

```

**Descripción:** Respuesta de la búsqueda de un log individual de filebeat

### Verificación:

- ☒ Log perteneciente al índice "filebeat-juice-shop-2025.11.21"

### Verificación de Éxito

- ☒ Filebeat corriendo sin errores
- ☒ Conectado a Elasticsearch
- ☒ Índices filebeat-\* creados
- ☒ Logs con metadata completa
- ☒ 5 screenshots capturados

### Conceptos Aprendidos

1. **Filebeat:** [Explica]
2. **Log Shipping:** [Explica]
3. **Processors:** [Explica]

## Paso 5: Visualización en Kibana

### Objetivo

Configurar Data Views, crear visualizaciones y armar dashboards.

### Configuraciones Realizadas

#### Data Views Creados

##### Data View 1: Todos los Logs

- Name: Todos los Logs
- Index pattern: filebeat-\*
- Timestamp field: @timestamp

##### Data View 1: Todos los Logs

- Name: Todos los Logs
- Index pattern: filebeat-\*
- Timestamp field: @timestamp

#### Visualizaciones Creadas

##### Visualización 1: Distribución por Contenedor

- Tipo: Pie Chart
- Segmentación: container.name.keyword
- Métrica: Conteo de registros

##### Visualización 2: Volumen en el Tiempo

- Tipo: Line Chart

- Eje horizontal: @timestamp
- Eje vertical: Conteo de registros
- Segmentación: container.name.keyword

**Visualización 3: Top 10 de mensajes de Juice Shop**

- Tipo: Tabla
- Filas: message.keyword
- Métrica: Conteo de registros

**Visualización 4: Total de logs**

- Tipo: Métrica (Legacy)
- Métrica: Conteo de registros

**Dashboard Creado**

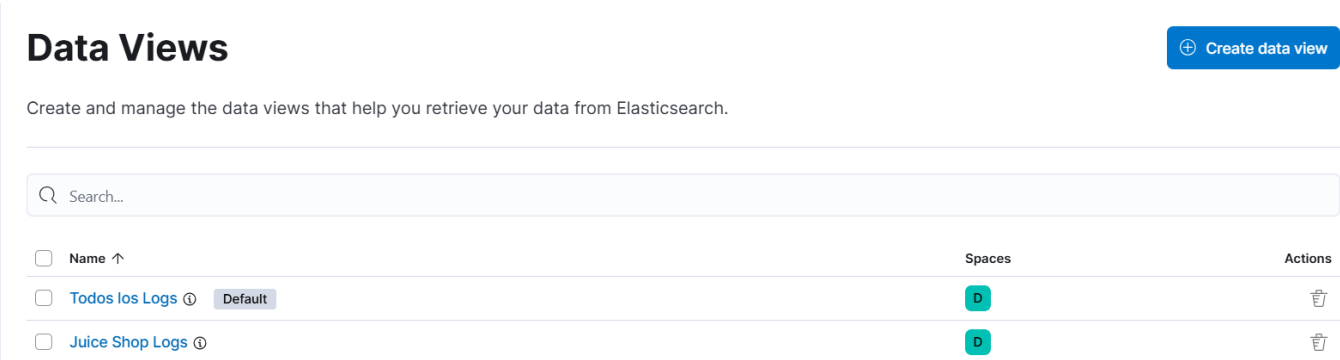
**Nombre:** Overview de Logs del Sistema

**Visualizaciones incluidas:**

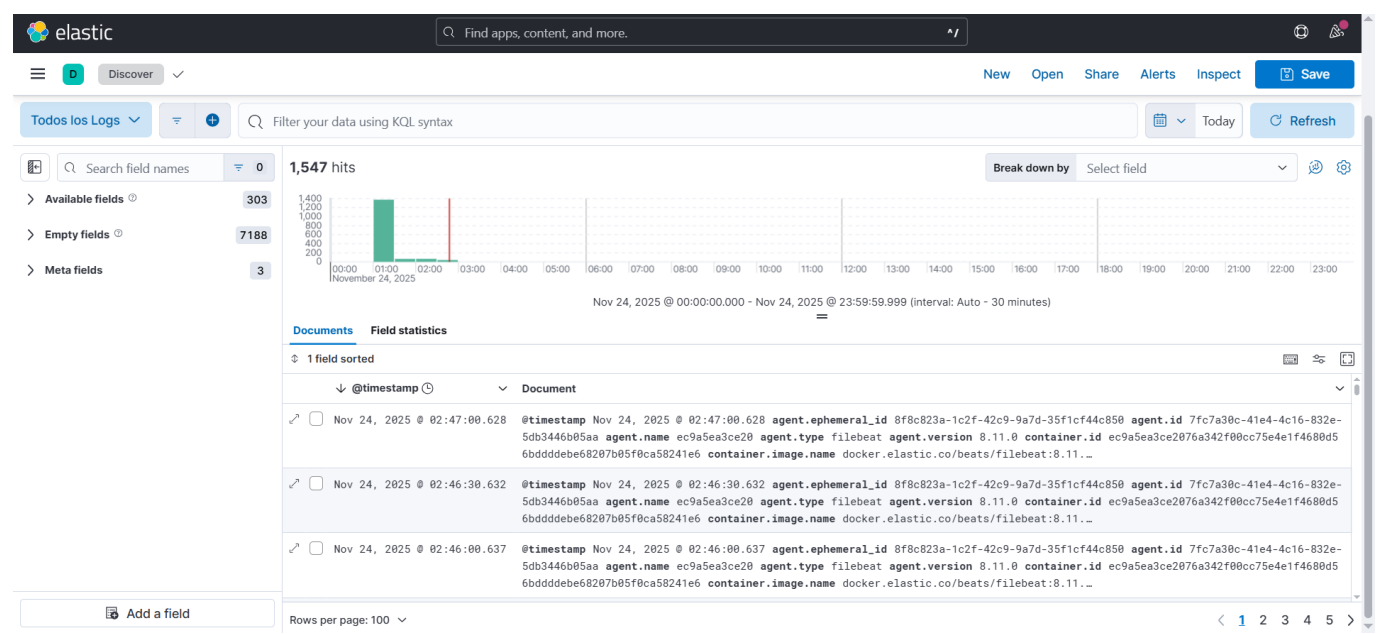
1. Gráfico circular mostrando distribución de logs por contenedor
2. Líneas de tiempo mostrando volumen de logs por contenedor
3. Tabla con los 10 mensajes más frecuentes de Juice Shop
4. Número grande mostrando total de logs

Screenshots

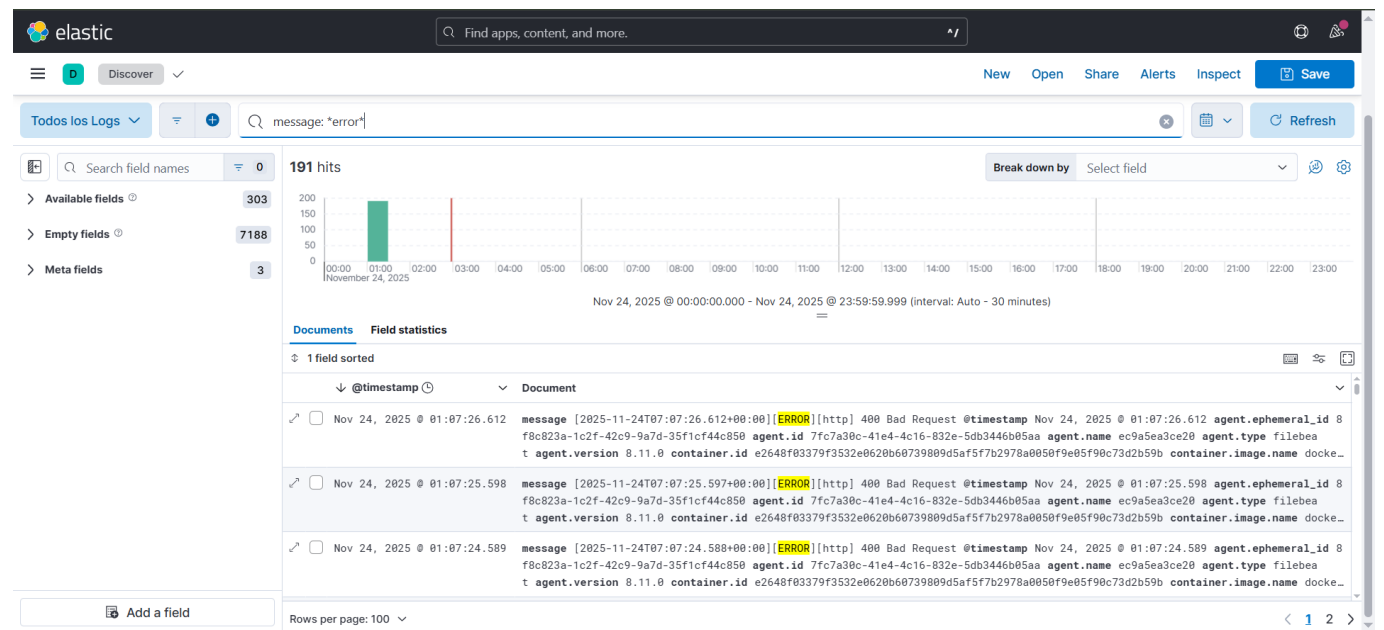
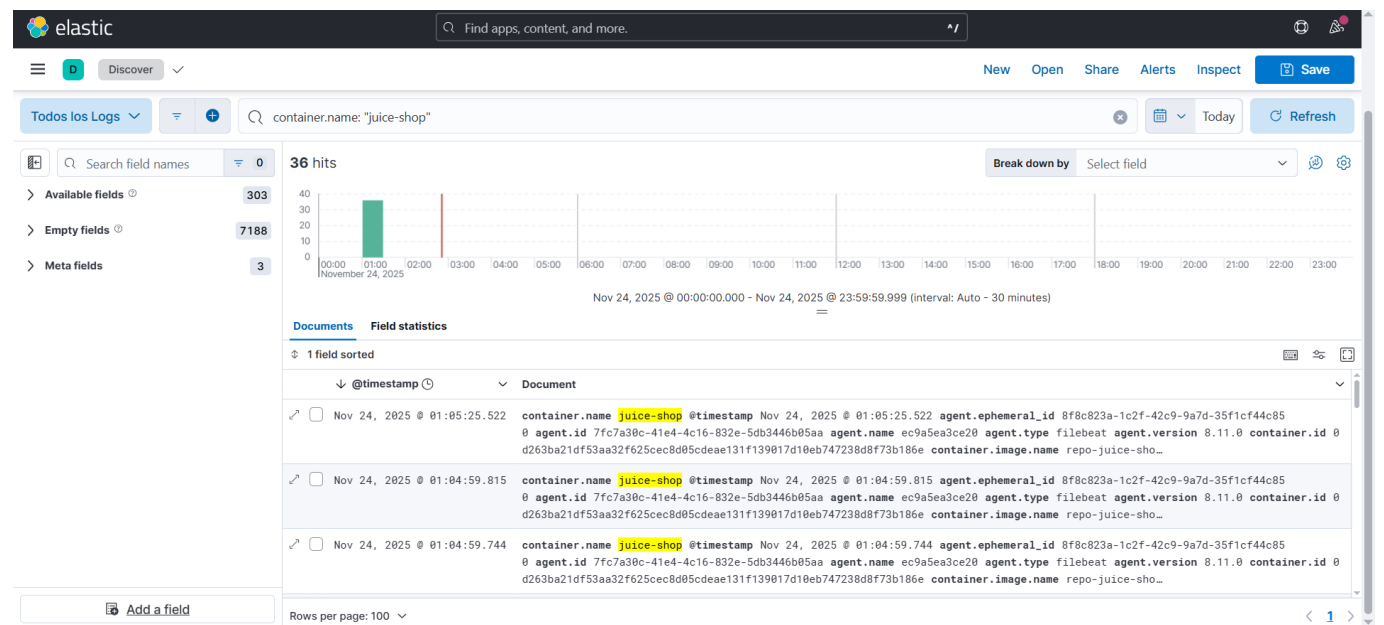
**Screenshot 5.1: Creación de Data View**

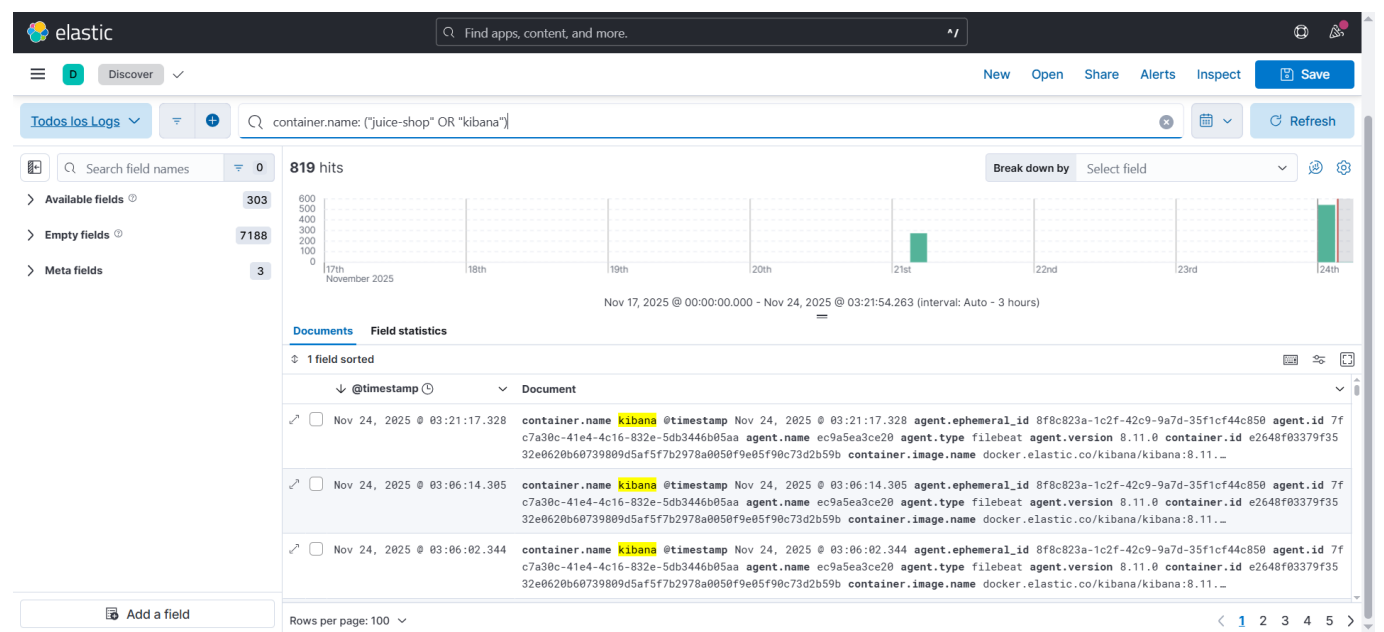


**Screenshot 5.2: Discover mostrando logs**

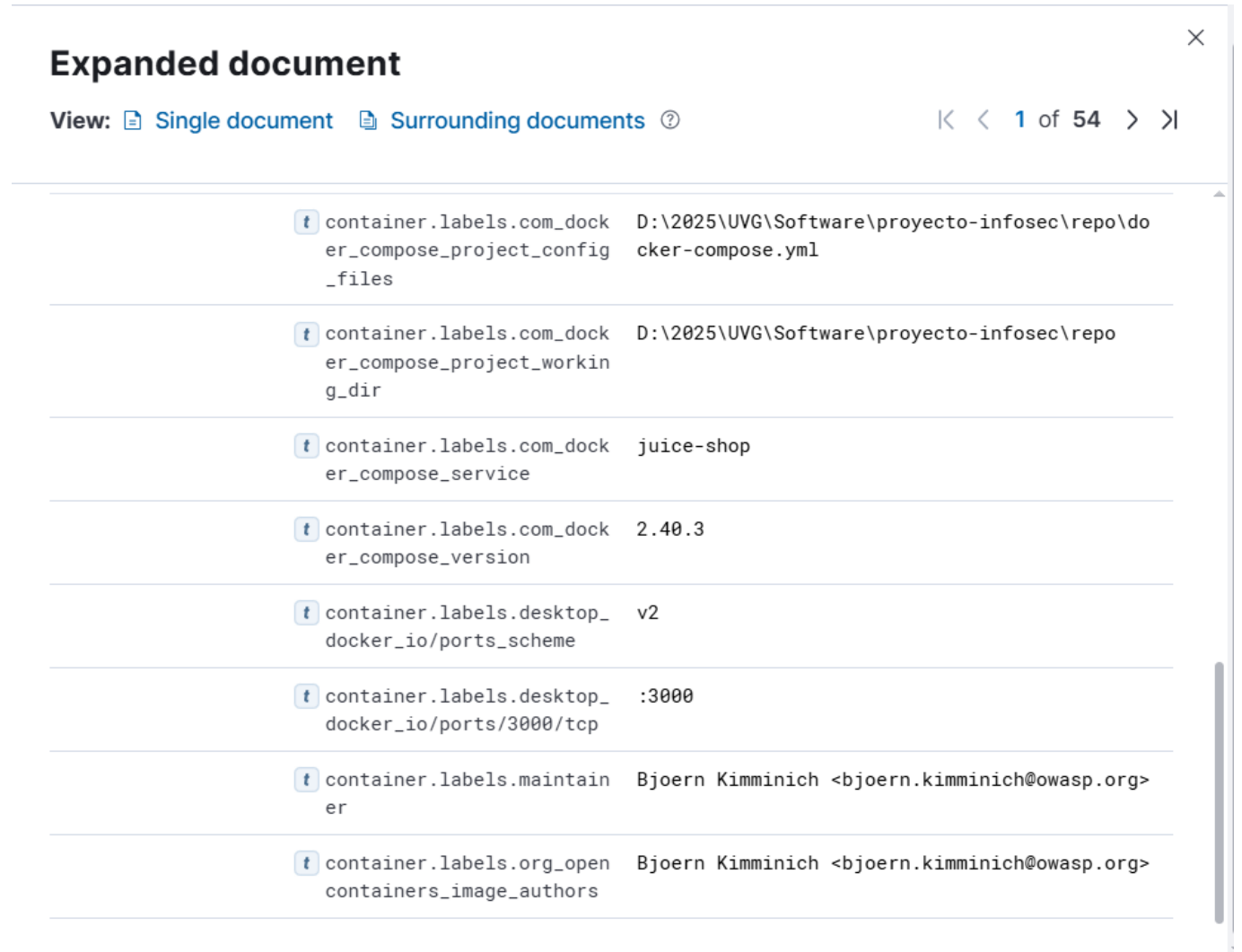


Screenshot 5.3: Búsqueda con KQL

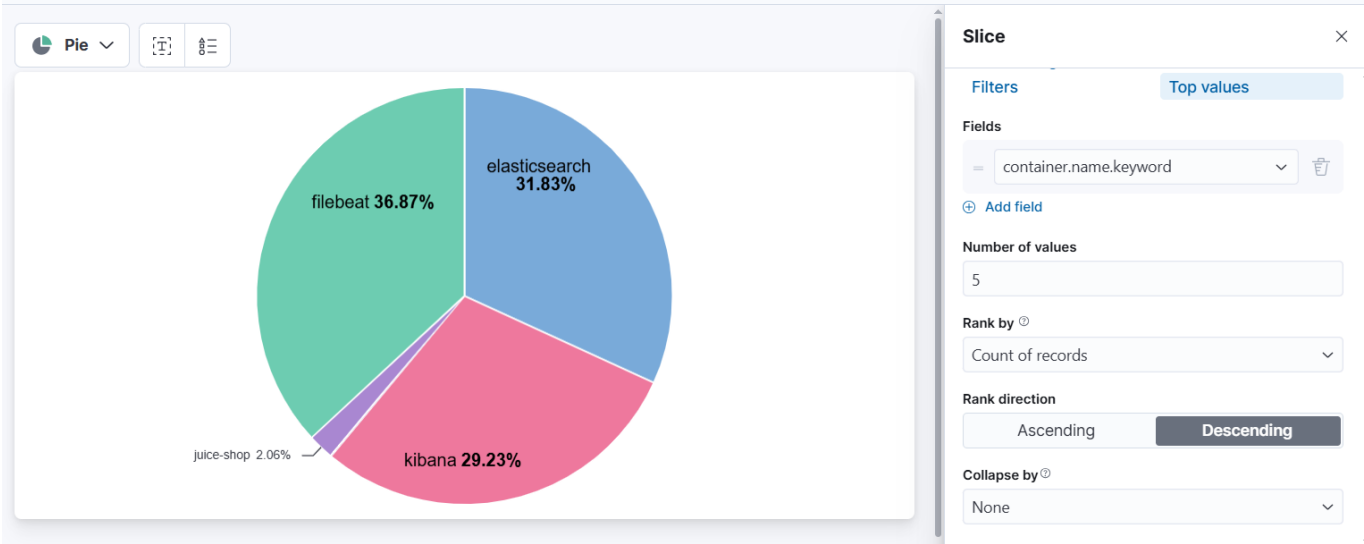




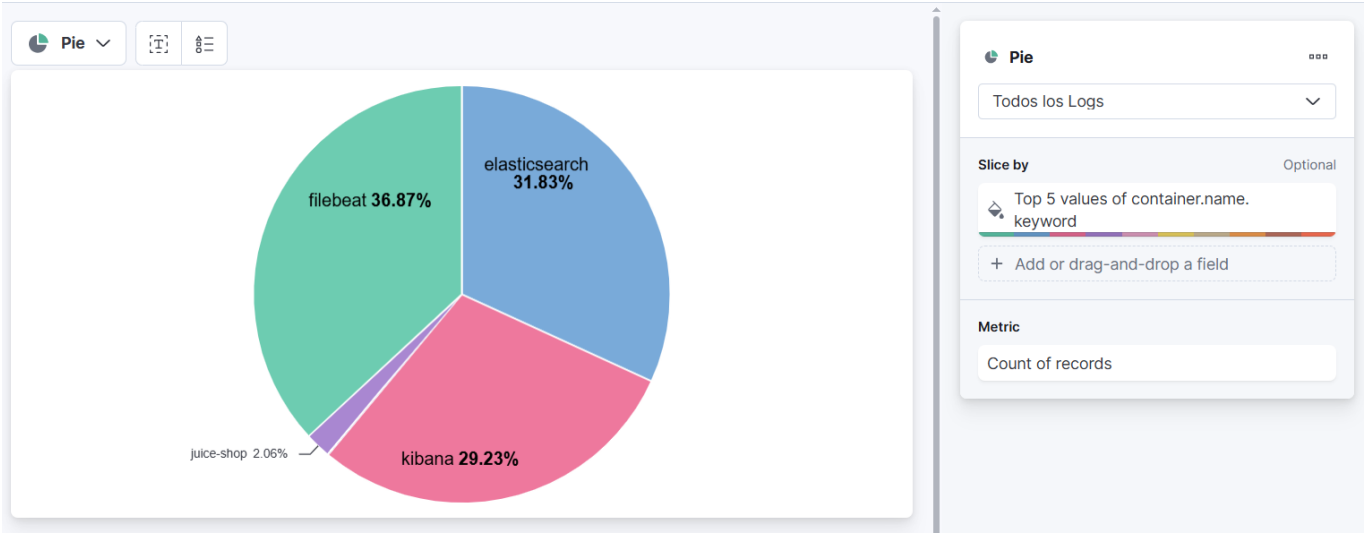
Screenshot 5.4: Log expandido con todos los campos



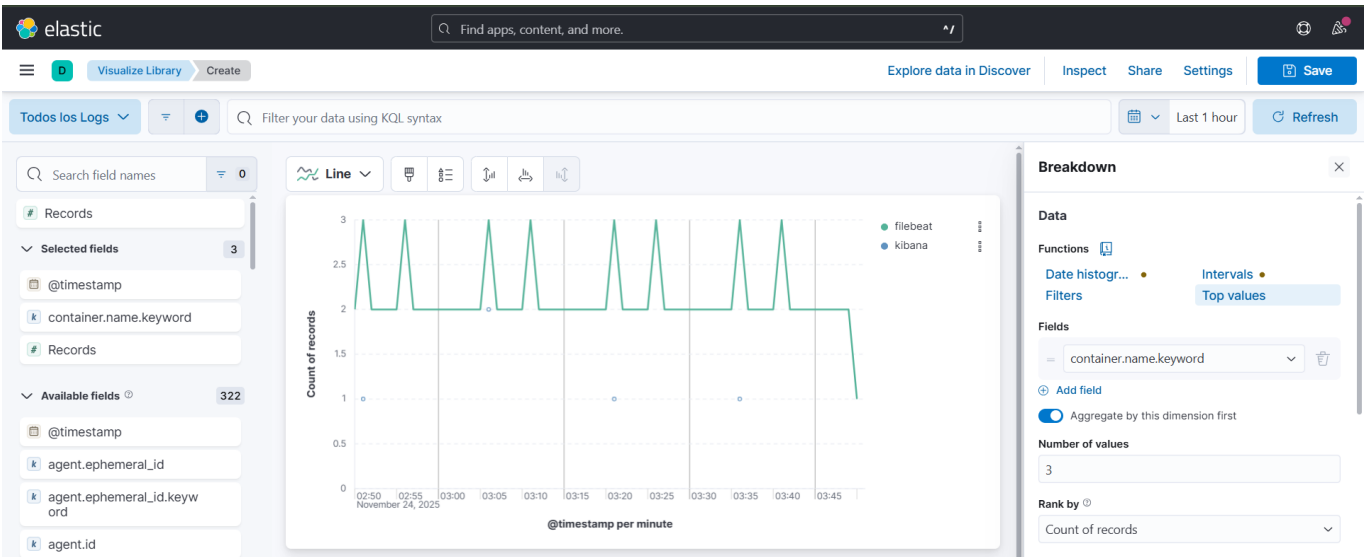
Screenshot 5.5: Creación de Pie Chart



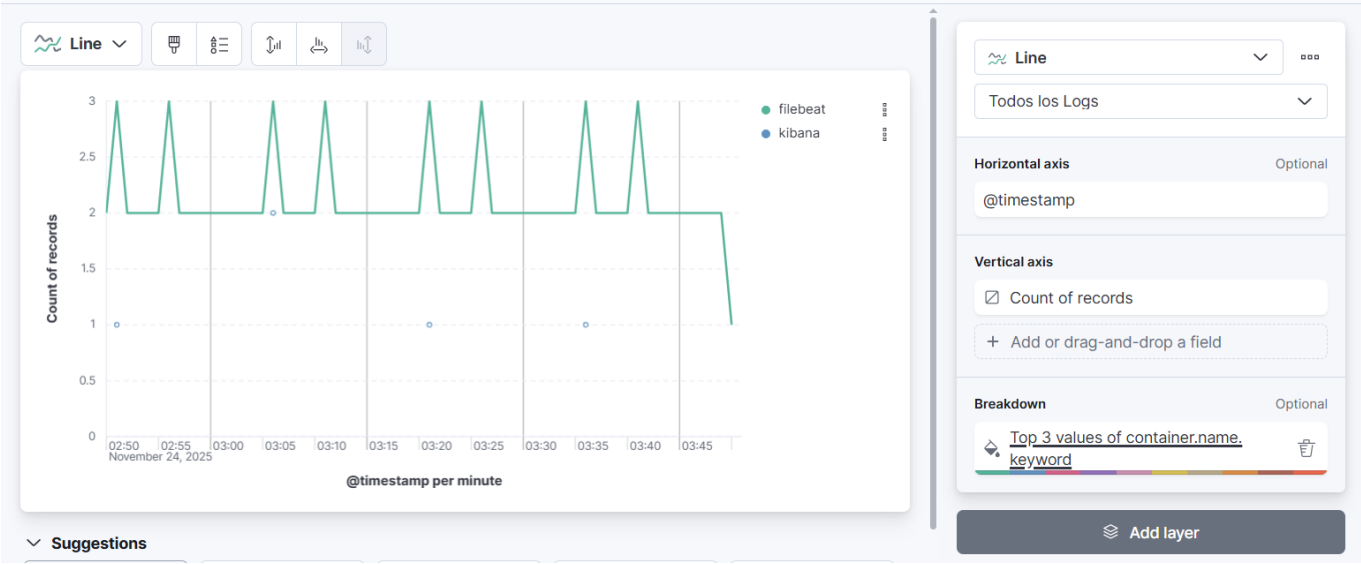
Screenshot 5.6: Pie Chart completado



Screenshot 5.7: Creación de Line Chart



Screenshot 5.8: Line Chart completado



Screenshot 5.9: Creación de Tabla

Top 5 values of message.keyword

Count of records

at processTicksAndRejections (node:internal/process/tas	13
at KibanaTransport.request (/usr/share/kibana/node_moc	7
at KibanaTransport.request (/usr/share/kibana/node_moc	7
at /usr/share/kibana/node_modules/@kbn/alerting-plugin	5
at AsyncLocalStorage.run (node:async_hooks:338:14)	4
Other	666

Row

Data

Functions: Date histogr..., Intervals, Filters, Top values

Fields: message.keyword

Number of values: 5

Rank by: Count of records

Rank direction: Ascending, Descending

Screenshot 5.10: Tabla completada

Top 5 values of message.keyword

Count of records

at processTicksAndRejections (node:internal/process/tas	13
at KibanaTransport.request (/usr/share/kibana/node_moc	7
at KibanaTransport.request (/usr/share/kibana/node_moc	7
at /usr/share/kibana/node_modules/@kbn/alerting-plugin	5
at AsyncLocalStorage.run (node:async_hooks:338:14)	4
Other	666

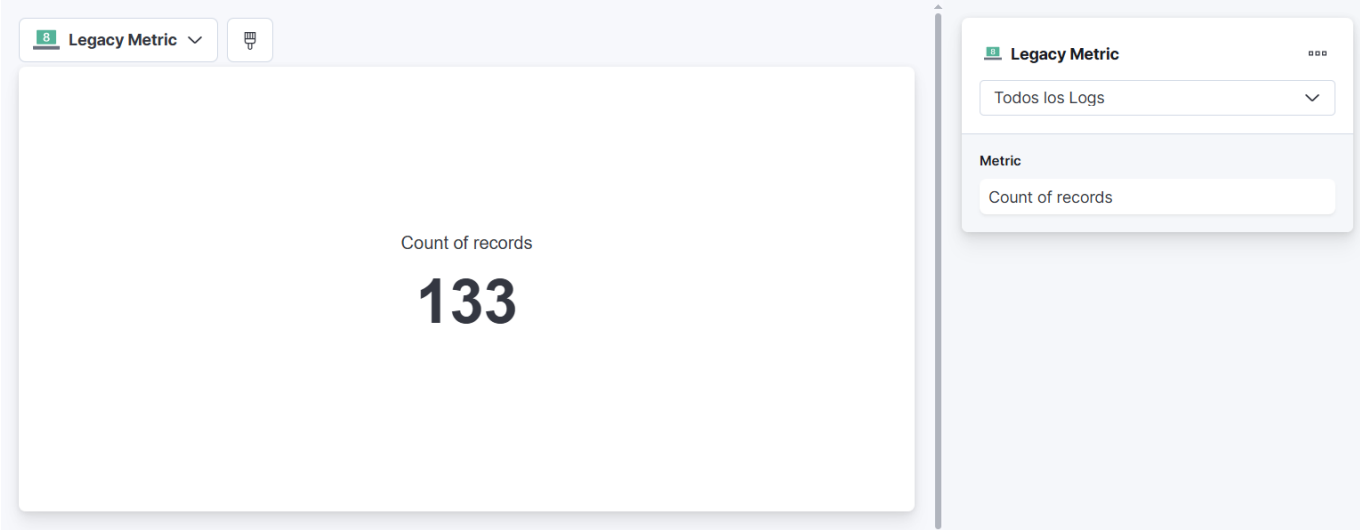
Table

Todos los Logs

Rows: Top 5 values of message.keyword

Split metrics by: Count of records

Screenshot 5.11: Metric completado



Screenshot 5.12: Visualize Library con las visualizaciones

The screenshot shows the Elastic Visualize Library interface. At the top, there is a search bar and a "Create visualization" button. Below this, there is a table listing several visualizations. The table has columns for "Name, description, tags", "Type", "Last updated", and "Actions".

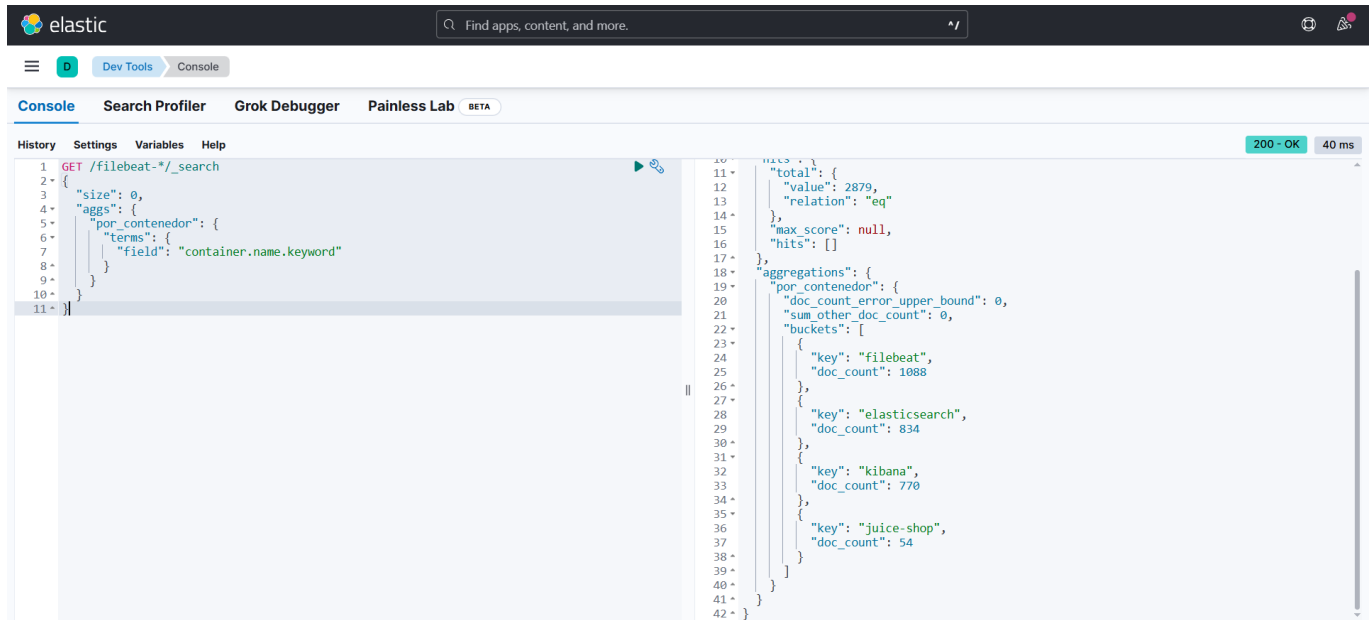
Name, description, tags	Type	Last updated	Actions
Todos los Logs	Lens	2 minutes ago	<a href="#">Edit</a> <a href="#">Info</a>
Top 10 Mensajes de Juice Shop	Lens	3 minutes ago	<a href="#">Edit</a> <a href="#">Info</a>
Volumen de Logs en el Tiempo	Lens	23 minutes ago	<a href="#">Edit</a> <a href="#">Info</a>
Distribución de Logs por Contenedor	Lens	48 minutes ago	<a href="#">Edit</a> <a href="#">Info</a>

Screenshot 5.13: Dashboard completo

The screenshot shows the Elastic Visualize Library interface. At the top, there is a search bar and a "Create visualization" button. Below this, there is a table listing several visualizations. The table has columns for "Name, description, tags", "Type", "Last updated", and "Actions".

Name, description, tags	Type	Last updated	Actions
Todos los Logs	Lens	2 minutes ago	<a href="#">Edit</a> <a href="#">Info</a>
Top 10 Mensajes de Juice Shop	Lens	3 minutes ago	<a href="#">Edit</a> <a href="#">Info</a>
Volumen de Logs en el Tiempo	Lens	23 minutes ago	<a href="#">Edit</a> <a href="#">Info</a>
Distribución de Logs por Contenedor	Lens	48 minutes ago	<a href="#">Edit</a> <a href="#">Info</a>

Screenshot 5.14: Dev Tools con query avanzada



## Búsquedas KQL Utilizadas

# Búsqueda 1: Solo logs de Juice Shop  
 container.name: "juice-shop"

# Búsqueda 2: Mensajes que contienen 'error'  
 message: \*error\*

# Búsqueda 3: Mensajes de Juice Shop o Kibana  
 container.name: ("juice-shop" OR "kibana")

## Verificación de Éxito

- ☒ Data View creado
- ☒ Discover funcional
- ☒ 3 visualizaciones creadas
- ☒ Dashboard creado
- ☒ 12 screenshots capturados

## Conceptos Aprendidos

1. **Data Views:** [Explica]
2. **KQL:** [Explica]
3. **Visualizaciones:** [Explica]
4. **Dashboards:** [Explica]

## Paso 6: Blue Team & Red Team

## Blue Team: Reglas de Detección

### Regla 1: Detección de SQL Injection

#### Configuración:

- Name: Detección SQL Injection
- Type: Custom query
- Query: `request_uri: (OR or UNION or SELECT or INSERT or DROP or -- or %27 or 1=1)`
- Severity: High
- Risk score: 80

#### Prueba:

```
curl "http://localhost:8080/rest/products/search?q=' OR '1'='1"
```

**Resultado:** Sí fue posible detectar el intento de ataque por SQL injection, levantando la alerta correspondiente.

#### Limitaciones:

Esta regla es muy sensible porque dispara solo por ver palabras clave de SQL en cualquier parte del `request_uri`. Cualquier tutorial, documentación o foro donde los usuarios hablen de consultas SQL legítimas puede generar alertas. Además, el `--` se usa en muchas URLs como separador visual, no necesariamente como comentario SQL. Incluir `%27` (comilla simple codificada) también puede generar ruido, porque es un carácter frecuente en textos naturales. Sin contexto de parámetros, método HTTP, destino (`/rest/products/search` vs `/blog/...`) o frecuencia por IP, la regla genera muchos falsos positivos, especialmente en sitios educativos, foros de desarrolladores o aplicaciones con contenido técnico. Es útil como primera señal, pero necesita correlación o condiciones adicionales para que sea realmente accionable.

Ejemplo de falsos positivo:

```
curl "/rest/products/search?q=how+to+select+the+best+product"
```

### Regla 2: Detección de XSS

#### Configuración:

- Name: Detección SQL Injection
- Type: Custom query
- Query: `request_uri:(%3Cscript or %3Cimg or javascript or onerror or alert)`
- Severity: High
- Risk score: 75

#### Prueba:

```
curl "http://localhost:8080/rest/products/search?q=<script>alert('xss')</script>"
```

**Resultado:** Fue posible detectar el intento de ataque XSS.

#### Limitaciones:

La regla es demasiado genérica, ya que salta solo por ver cadenas como javascript, alert o %3Cimg, que aparecen en contenido legítimo de desarrollo web, documentación, laboratorios y blogs, generando muchas falsas alarmas.

Además, no toma en cuenta el contexto del payload (ruta, parámetro, tipo de usuario, frecuencia o código de respuesta HTTP), ni diferencia entre campos pensados para código (como un editor de snippets) y campos normales. Sin ese contexto, la señal de XSS es muy ruidosa. Lo ideal es combinar estas cadenas con rutas específicas de la app, parámetros sospechosos (q, search, comment, etc.) y, si se puede, con errores o comportamientos anómalos en la respuesta.

Ejemplo de falso positivo:

```
curl "/blog/xss?example=%3Cscript%3Ealert('test')%3C/script%3E"
```

### Regla 3: Regla Brute Force

#### Configuración:

- Name: Detección Brute force
- Type: Custom query
- Query: (message: (Invalid email or password or 401 or authentication failed)) or (request\_uri: /rest/user/login and status: 401)
- Severity: High
- Risk score: 70

#### Prueba:

```
Intentos fallidos de login
for i in {1..10}; do
 curl -X POST "http://localhost:8080/rest/user/login" \
 -H "Content-Type: application/json" \
 -d "{\"email\":\"admin@juice-sh.op\",\"password\":\"wrongpass$i\"}"
 sleep 1
done
```

**Resultado:** Fue posible detectar el intento de acceso por medio de fuerza bruta.

#### Limitaciones:

La regla solo busca mensajes de error de autenticación o respuestas 401 sin agrupar por IP/usuario ni aplicar umbrales de frecuencia. Así, cualquier fallo de login aislado puede dispararla, y esos mismos mensajes pueden aparecer en contextos legítimos (por ejemplo, APIs internas).

Sin lógica de agregación como "más de N fallos de login desde la misma IP o usuario en T minutos", habrá mucho ruido por usuarios que se equivocan, integraciones mal configuradas o pruebas. Para que indique realmente un brute force, la regla debería añadir conteos y límites por IP, usuario y ventana de tiempo.

Ejemplo de falso positivo:

Usuario que se equivoca varias veces en su email o contraseña.

```
curl "/rest/user/login HTTP/1.1"
```

## Regla 4: Traffic Scanner

### Configuración:

- Name: Detección Brute force
- Type: Custom query
- Query: `http_user_agent: (sqlmap or nmap or burp or nikto or python-requests or Nuclei or masscan or ZAP or Acunetix or Nessus)`
- Severity: medium
- Risk score: 60

### Prueba:

```
curl -A "sqlmap/1.7.2" "http://localhost:8080/rest/products/search?q=test"
```

**Resultado:** Fue posible detectar escaneos de tráfico.

### Limitaciones:

La regla marca como malicioso cualquier User-Agent de escaneo, aunque suele ser tráfico interno legítimo o monitorización. Además, un atacante puede cambiar fácilmente el User-Agent y evadirla. Sirve como indicio de reconocimiento automatizado, pero necesita cruzarse con horarios de mantenimiento, IP internas, listas de escaneos permitidos y otras señales para distinguir entre escaneo autorizado y ataque real.

Ejemplo de falso positivo:

Equipo interno de seguridad ejecutando un escaneo autorizado con Burp o sqlmap

```
GET / HTTP/1.1
User-Agent: sqlmap/1.6.12#stable
```

## Regla 5: Command Injection

### Configuración:

- Name: Detección Brute force
- Type: Custom query
- Query: `request_uri.keyword: %3B or request_uri.keyword: %7C or request_uri.keyword: %60`
- Severity: critical
- Risk score: 90

### Prueba:

```
http://localhost:8080/ping?ip=127.0.0.1;cat%20/etc/passwd
```

**Resultado:** Fue posible detectar ataques de inyección de comandos.

### Limitaciones:

La regla es muy ruidosa porque solo detecta caracteres codificados comunes (%3B, %7C, %60) que aparecen mucho en tráfico legítimo, sobre todo en URLs, filtros, documentación y snippets de código. No tiene en cuenta la ruta, el contexto ni patrones claros de explotación, así que se dispara incluso con ejemplos de comandos normales. Por sí sola genera muchos falsos positivos y solo sirve como indicio débil que hay que correlacionar con otros factores (endpoint sensible, combinación de operadores, repetición por IP, errores del servidor).

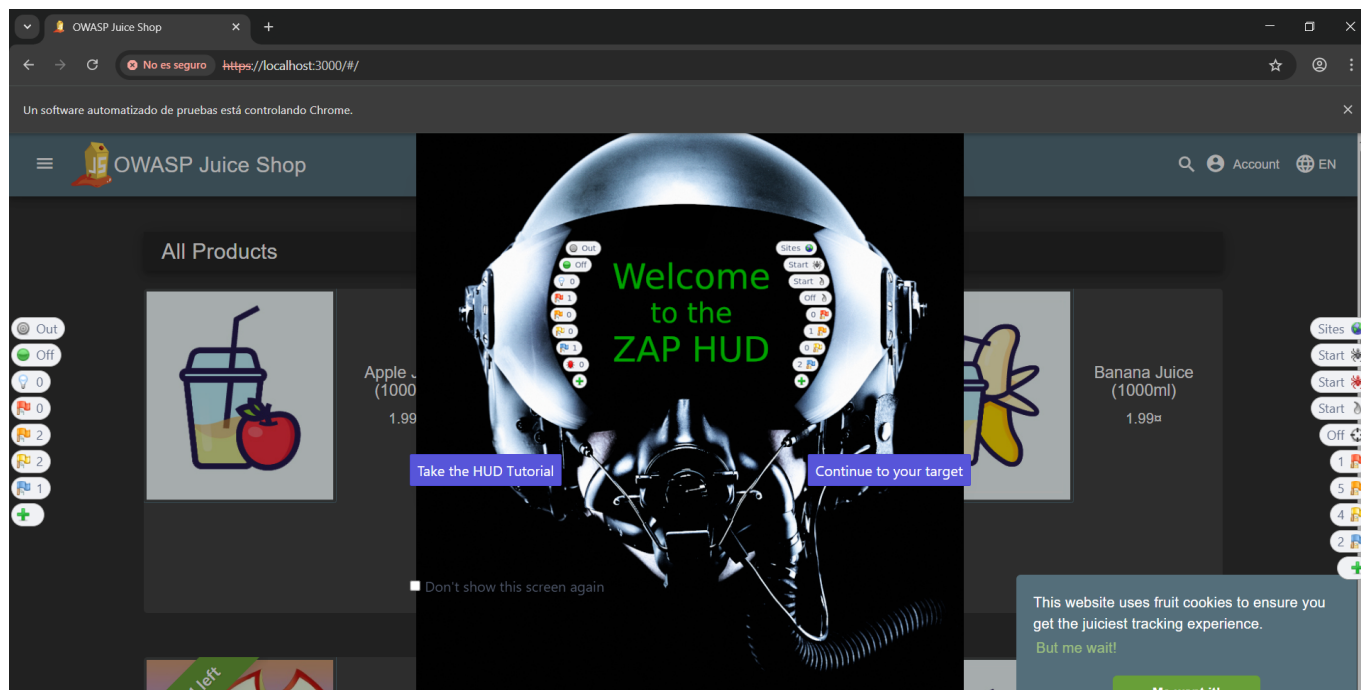
Ejemplo de falso positivo:

Un usuario abre una página de documentación interna donde se muestran ejemplos de comandos para desplegar una app.

```
https://intranet.empresa.local/docs/deploy?cmd=git%20pull%3B%20npm%20install%20%7C%7C%20echo%20%60error%60
```

### Red Team: DAST

Se efectuaron tres tipos de escaneo con OWASP ZAP: automatizado, activo y manual. Asimismo, se ejecutaron las herramientas Spider y AJAX Spider, utilizando credenciales válidas de autenticación para permitirles explorar más allá de la página de inicio de sesión. Durante los escaneos se encontraron 683 URLs únicas y se realizaron 7724 peticiones:



Historial

Buscar

Aleras

Output

Spider(Araña)

AJAX Spider

Escanear Activo

WebSockets

Nuevo escaneo

Progreso: 1: http://localhost:3000

100 %

Escanear actual: 0

Las URL que fueron encontradas: 605

Nodos ingresados: 492

Exportar

URLs vulnerables

Nodos ingresados

Mensajes

Procesado	Método	URI	Banderas
	GET	http://localhost:3000	Semilla
	GET	http://localhost:3000/robots.txt	Semilla
	GET	http://localhost:3000/sitemap.xml	Semilla
	GET	http://localhost:3000/	Semilla
	GET	http://localhost:3000/assets	Semilla
	GET	http://localhost:3000/assets/public	Semilla
	GET	http://localhost:3000/ftp	Semilla
	GET	http://localhost:3000/ftp/acquisitions.md	Semilla
	GET	http://localhost:3000/ftp/announcement_encrypted.md	Semilla
	GET	http://localhost:3000/ftp/coupons_2013.md.bak	Semilla
	GET	http://localhost:3000/ftp/easteregg	Semilla
	GET	http://localhost:3000/ftp/encrypt.pyrc	Semilla
	GET	http://localhost:3000/ftp/incident-support.kdbx	Semilla
	GET	http://localhost:3000/ftp/legal.md	Semilla
	GET	http://localhost:3000/ftp/index.html	Semilla

Aleras

1

10

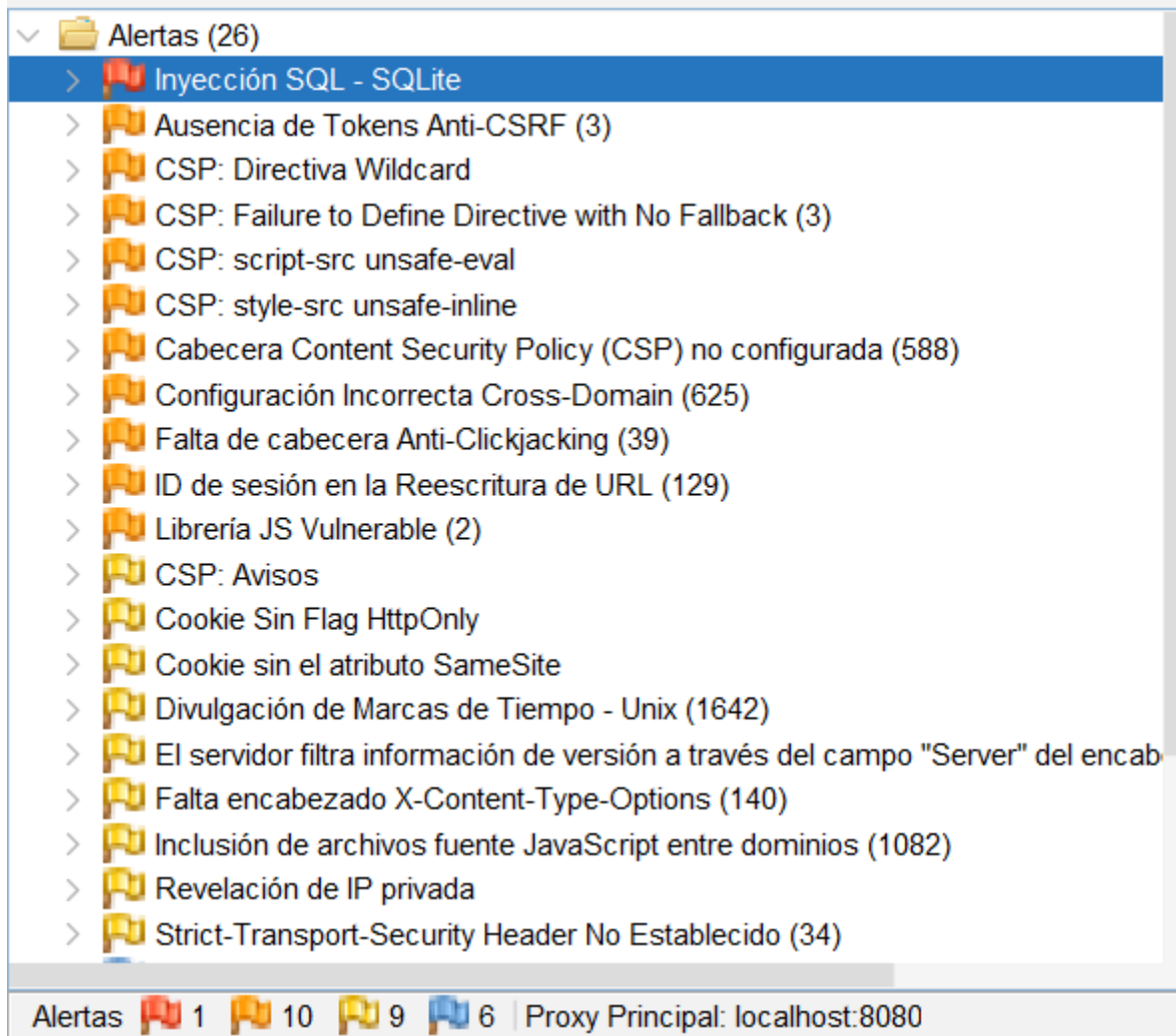
9

6

Proxy Principal: localhost:8080

Current Status

Luego de recorrer las páginas del frontend y realizar las múltiples solicitudes al backend, se encontró 1 alerta de alta prioridad, 10 de prioridad media, 9 de baja prioridad y 6 informativas.



- La alerta de alta prioridad indica la posibilidad de inyección SQL (SQLi) en los endpoints `/rest/user/login` y `/rest/product/search?q=`.
- Las alertas de prioridad media indican, sobre todo, los problemas derivados de la ausencia de una Content Security Policy (CSP).
- Las alertas de baja prioridad indican las posibles vulnerabilidades debido a problemas con encabezados ausentes en las solicitudes, cookies mal configuradas y archivos de código fuente expuestos.

## Red Team: Vulnerabilidades Explotadas

### Vulnerabilidad 1: Exposición de rutas

#### Descripción Técnica:

Debido a que el *frontend* de Juice Shop es una *Single Page Application* (SPA), herramientas como *dirbuster* o *gobuster* no resultan del todo útiles para encontrar todas las rutas que ofrece la aplicación, ya que las SPAs usualmente cuentan con un *fallback* de ruteo; es decir, si una ruta especificada por el usuario no está definida, se redirige a una página por defecto, haciendo que cualquier ruta que se pruebe durante el reconocimiento retorne un estatus "200 OK". Por suerte, el código fuente de Juice Shop (`main.js`) parece definir todas las rutas de la aplicación.

Este comportamiento no representa un fallo de seguridad por sí mismo, pero puede facilitar el reconocimiento durante una fase de enumeración, permitiendo a un atacante descubrir funcionalidades o rutas del frontend más fácilmente.

## Pasos para Reproducir:

1. Ingresar a la interfaz gráfica de Juice Shop desde el navegador.
2. Capturar el tráfico de solicitudes con las DevTools del navegador o con BurpSuite.
3. Recargar la página y buscar el archivo "main.js" dentro de las respuestas.
4. Buscar la sección de código en la que se definen las rutas que soporta la aplicación.

## Impacto:

- **Confidencialidad:** ● BAJO - Solo revela rutas del frontend, no datos sensibles.
- **Integridad:** ● BAJO - No permite modificar información.
- **Disponibilidad:** ● BAJO - No afecta el rendimiento ni provoca denegación de servicio.

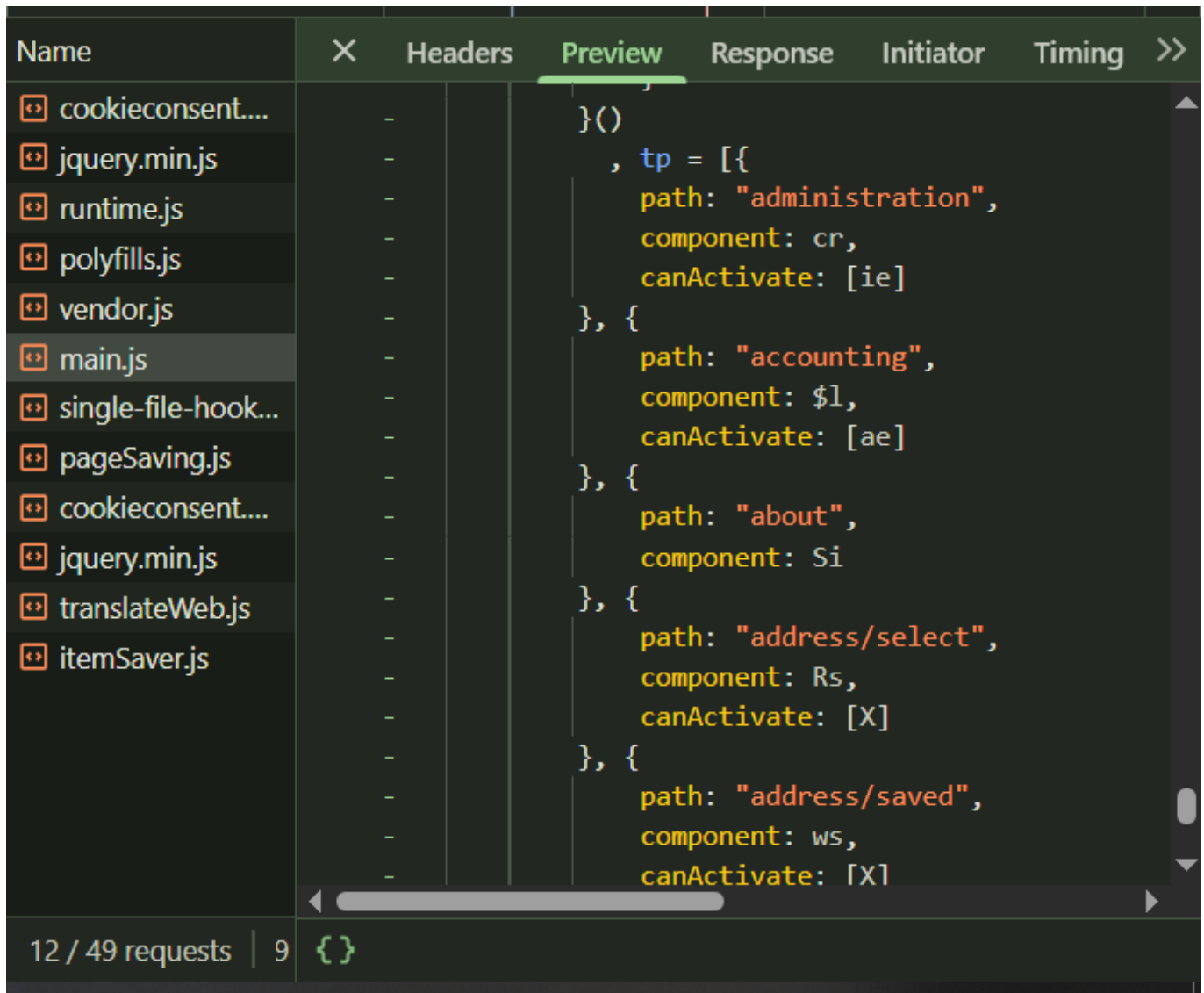
## Clasificación:

- **CWE:** CWE-200: Information Exposure
- **OWASP Top 10:** A01:2021 - Broken Access Control
- **CVSS v3.1:** 3.1 (Low)
- **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

## Cálculo CVSS:

- **AV:N** (Attack Vector: Network) - Se explota desde el navegador sin acceso local.
- **AC:L** (Attack Complexity: Low) - Basta abrir main.js.
- **PR:N** (Privileges Required: None) - No requiere autenticación.
- **UI:N** (User Interaction: None) - No requiere interacción adicional.
- **C:L** (Confidentiality: Low) - Exposición mínima de información no sensible.
- **I:N** (Integrity: None) - No se altera información.
- **A:H** (Availability: None) - No afecta disponibilidad.

## Screenshots:



## Vulnerabilidad 2: SQL Injection en Login

### Descripción Técnica:

SQL Injection es una vulnerabilidad que ocurre cuando una aplicación web construye consultas SQL concatenando directamente la entrada proporcionada por el usuario sin validación ni sanitización adecuada. Esto permite que un atacante inserte fragmentos de código SQL malicioso para:

- Alterar la lógica de autenticación
- Consultar o modificar información sensible
- Otener acceso no autorizado,
- Comprometer toda la base de datos.

La página de Login de Juice Shop presenta esta vulnerabilidad. Al navegar por todo el sitio utilizando el proxy de Burp Suite se capturó la llamada al endpoint `/rest/user/login`, el cual únicamente recibe el correo electrónico y contraseña del usuario en el cuerpo de la solicitud. Al inyectar SQL en el primero de estos campos, fue posible iniciar sesión como administrador.

**Endpoint Vulnerable:** `/rest/user/login`

### Pasos para Reproducir:



- **CWE:** CWE-89: Improper Neutralization of Special Elements used in an SQL Command
- **OWASP Top 10:** A03:2021 - Injection
- **CVSS v3.1:** 9.8 (Critical)
- **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

#### Cálculo CVSS:

- **AV:N** (Attack Vector: Network) - El ataque puede realizarse remotamente, enviando un request HTTP al endpoint vulnerable, sin acceso físico.
- **AC:L** (Attack Complexity: Low) - No requiere condiciones especiales, solo enviar un payload simple como ' OR 1=1--.
- **PR:N** (Privileges Required: None) - No es necesario estar autenticado; incluso un usuario anónimo puede explotar el endpoint.
- **UI:N** (User Interaction: None) - Ningún usuario legítimo debe realizar una acción para que el ataque se complete.
- **C:H** (Confidentiality: High) - Acceso total a los datos sensibles del sistema (por quedar autenticado como admin).
- **I:H** (Integrity: High) - El atacante puede modificar información crítica (productos, usuarios, inventario, configuraciones).
- **A:H** (Availability: High) - Aunque no es un ataque de DoS puro, un atacante autenticado como admin puede causar interrupciones significativas y dejar el sistema inutilizable.

#### Screenshots:



### Vulnerabilidad 3: Cross-Site Scripting (XSS) reflejado

#### Descripción Técnica:

Cross-Site Scripting (XSS) es una vulnerabilidad que permite a un atacante inyectar código JavaScript malicioso en una aplicación web. Este código se ejecuta en el navegador de la víctima, aprovechando que la aplicación refleja o almacena contenido proporcionado por el usuario sin realizar sanitización ni escape adecuado.

En el caso de XSS reflejado (reflected XSS), la carga útil enviada por el atacante es devuelta inmediatamente en la respuesta del servidor y ejecutada en el navegador cuando la víctima accede a la URL manipulada. Juice Shop es vulnerable porque la ruta de búsqueda `/search?q=` inserta la cadena enviada por el usuario directamente en la página, sin validación.

Esto permite ejecutar JavaScript arbitrario, abrir iframes maliciosos, robar cookies o tokens JWT, e incluso redirigir al usuario a sitios externos controlados por el atacante.

**Endpoint Vulnerable:** `/rest/products/search?q=`

#### Pasos para Reproducir:

1. Acceder al cuadro de búsqueda en la página principal de Juice Shop.
2. Ingresar el payload deseado en el cuadro de búsqueda. Alternativamente, enviar la solicitud desde BurpSuite o el navegador, inyectando el payload en el *query param* "q".
3. Cuando se reciba respuesta del endpoint `rest/products/search?q=`, el código se incrustará en el DOM.
4. El navegador ejecutará el código JavaScript malicioso embebido.

#### Payload Utilizado:

```
<iframe src="javascript:alert('XSS ejecutado exitosamente')">
```

#### Response Obtenida:

```
{
 "error": {
 "message": "SQLITE_ERROR: near \"XSS\": syntax error",
 "stack": "Error: SQLITE_ERROR: near \"XSS\": syntax error",
 "errno": 1,
 "code": "SQLITE_ERROR",
 "sql": "SELECT * FROM Products WHERE ((name LIKE '%<iframe src=\"javascript:alert('XSS ejecutado exitosamente')\">%\" OR description LIKE '%<iframe src=\"javascript:alert('XSS ejecutado exitosamente')\">%') AND deletedAt IS NULL) ORDER BY name"
 }
}
```

#### Impacto:

- **Confidencialidad:** ● MEDIO/ALTO - Permite robo de cookies o tokens JWT, lectura de información mostrada en pantalla o envío de datos a un servidor externo.
- **Integridad:** ● MEDIO - Un payload puede manipular el DOM cambiando textos, insertando botones falsos o modificando enlaces y formularios.
- **Disponibilidad:** ● BAJO/MEDIO - Se podría ejecutar JavaScript que bloquee el navegador, genere loops infinitos o redireccione a un sitio externo.

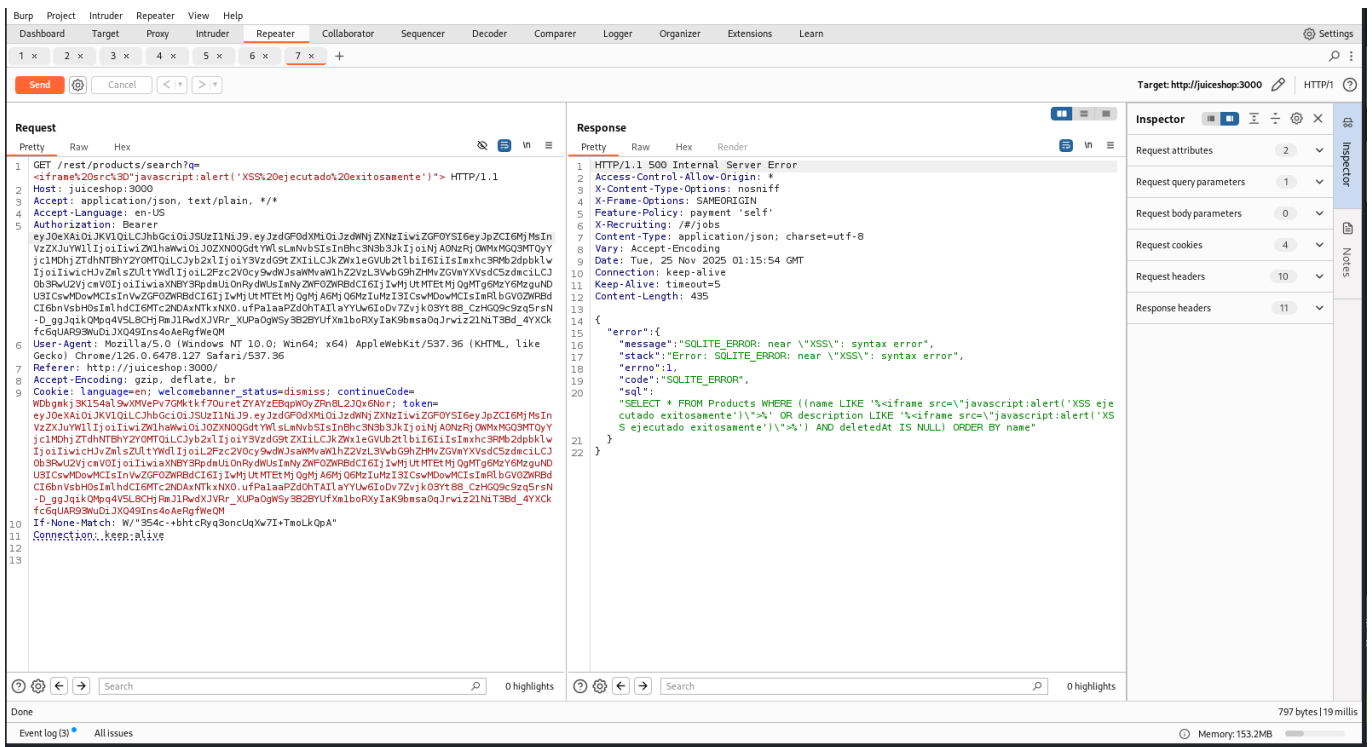
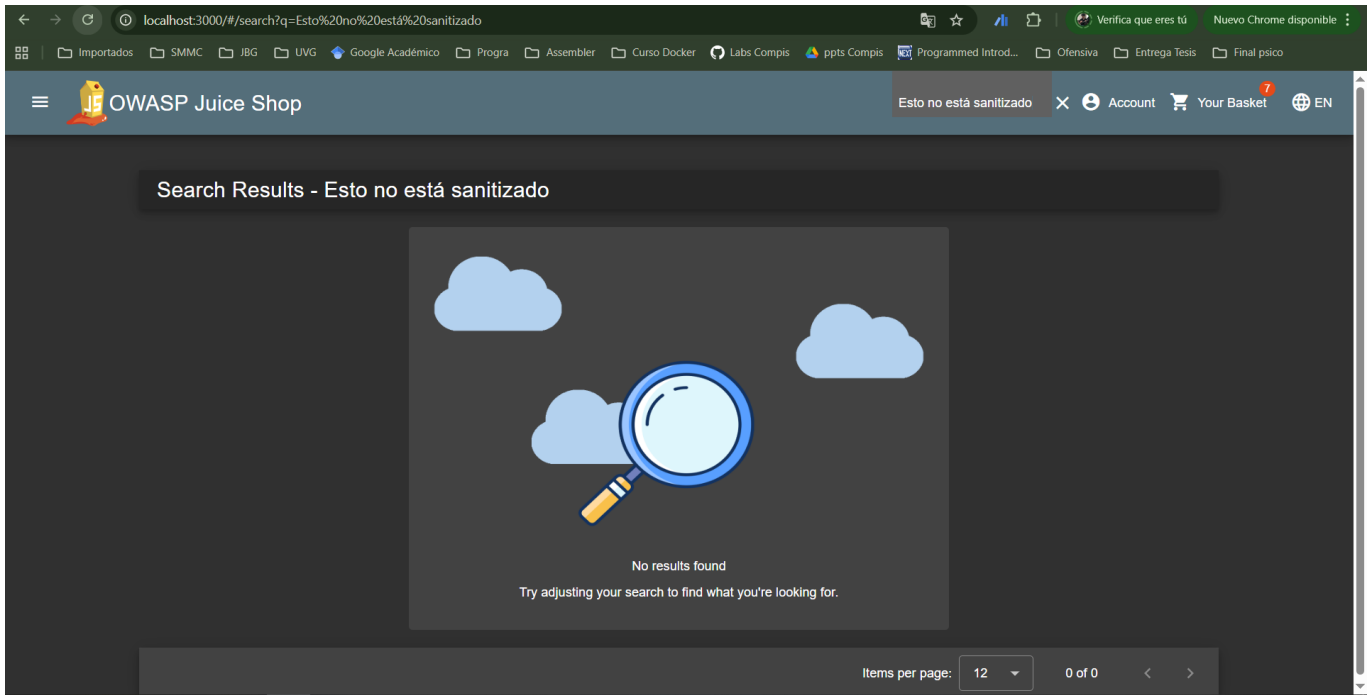
#### Clasificación:

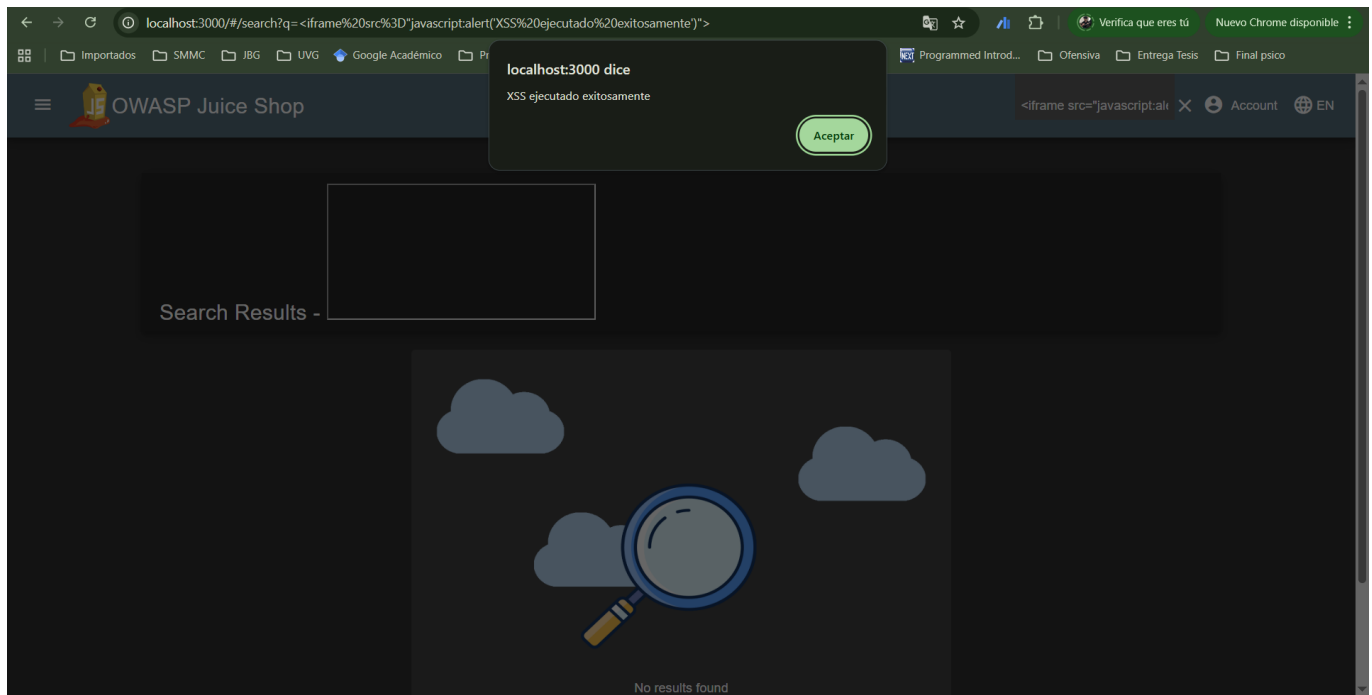
- **CWE:** CWE-79: Improper Neutralization of Input During Web Page Generation (Cross-Site Scripting)
- **OWASP Top 10:** A03:2021 - Injection
- **CVSS v3.1:** 6.1 - Medium
- **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

#### Cálculo CVSS:

- **AV:N** (Attack Vector: Network) - El ataque se ejecuta simplemente accediendo a una URL, no requiere acceso físico.
- **AC:L** (Attack Complexity: Low) - El payload es simple y no requiere condiciones especiales.
- **PR:N** (Privileges Required: None) - La vulnerabilidad es explotable por cualquier usuario anónimo.
- **UI:N** (User Interaction: Required) - La víctima debe abrir el enlace malicioso o usar el campo de búsqueda.
- **C:H** (Confidentiality: Low) - El atacante puede obtener información básica del usuario (cookies, tokens).
- **I:H** (Integrity: Low) - Puede manipular parcialmente el DOM, alterando el contenido visto por la víctima.
- **A:H** (Availability: None) - El objetivo principal no es detener la aplicación, aunque puede molestar la navegación.

#### Screenshots:





## Vulnerabilidad 4: Broken Access Control al cambiar contraseña

### Descripción Técnica:

Broken Access Control se presenta cuando una aplicación no implementa adecuadamente verificaciones de permisos, identidad u operaciones sensibles. En este caso, el endpoint `/rest/user/change-password` permite modificar la contraseña del usuario sin verificar la contraseña actual, ya que dicha validación ocurre únicamente en el frontend.

Esto significa que un atacante que obtenga un token JWT (por XSS, MITM, fuga de logs, sesión robada, etc.) puede cambiar la contraseña sin necesidad de conocer la contraseña actual, lo que implica un secuestro total y permanente de la cuenta.

**Endpoint Vulnerable:** `/rest/user/change-password`

### Pasos para Reproducir:

1. Obtener el token de sesión válido del usuario objetivo.
2. Realizar una solicitud GET (con el navegador o Burp Suite) a `/rest/user/change-password`, únicamente con los parámetros "new" y "repeat" (que deben ser iguales) con la nueva contraseña deseada.
3. El servidor omitirá la validación de la contraseña actual y actualizará la contraseña del usuario.

### Payload Utilizado:

```
curl -X GET "http://localhost:3000/rest/user/change-password?new=<nueva>&repeat=<nueva>" \
-H "Authorization: Bearer <TOKEN_VALIDO>"
```

### Response Obtenida:

```
{
 "user":{
 "id":23,
 "username":"",
 "email":"test@gmail.com",
 "password":"cc03e747a6afbcbcf8be7668acfebee5",
 "role":"customer",
 "deluxeToken":"",
 "lastLoginIp":"",
 "profileImage":"/assets/public/images/uploads/default.svg",
 "totpSecret":"",
 "isActive":true,
 "createdAt":"2025-11-24T18:36:38.457Z",
 "updatedAt":"2025-11-25T01:58:11.009Z",
 "deletedAt":null
 }
}
```

### Impacto:

- **Confidencialidad:** ● ALTO - Un atacante que haya obtenido un token JWT puede acceder permanentemente a la cuenta y todos sus datos privados.
- **Integridad:** ● ALTO - El atacante puede cambiar la contraseña, modificar datos del usuario e impersonarlo permanentemente.
- **Disponibilidad:** ● MEDIO - Aunque no es un ataque de DoS, el atacante puede bloquear al usuario legítimo de su propia cuenta e impedirle iniciar sesión al cambiar la password.

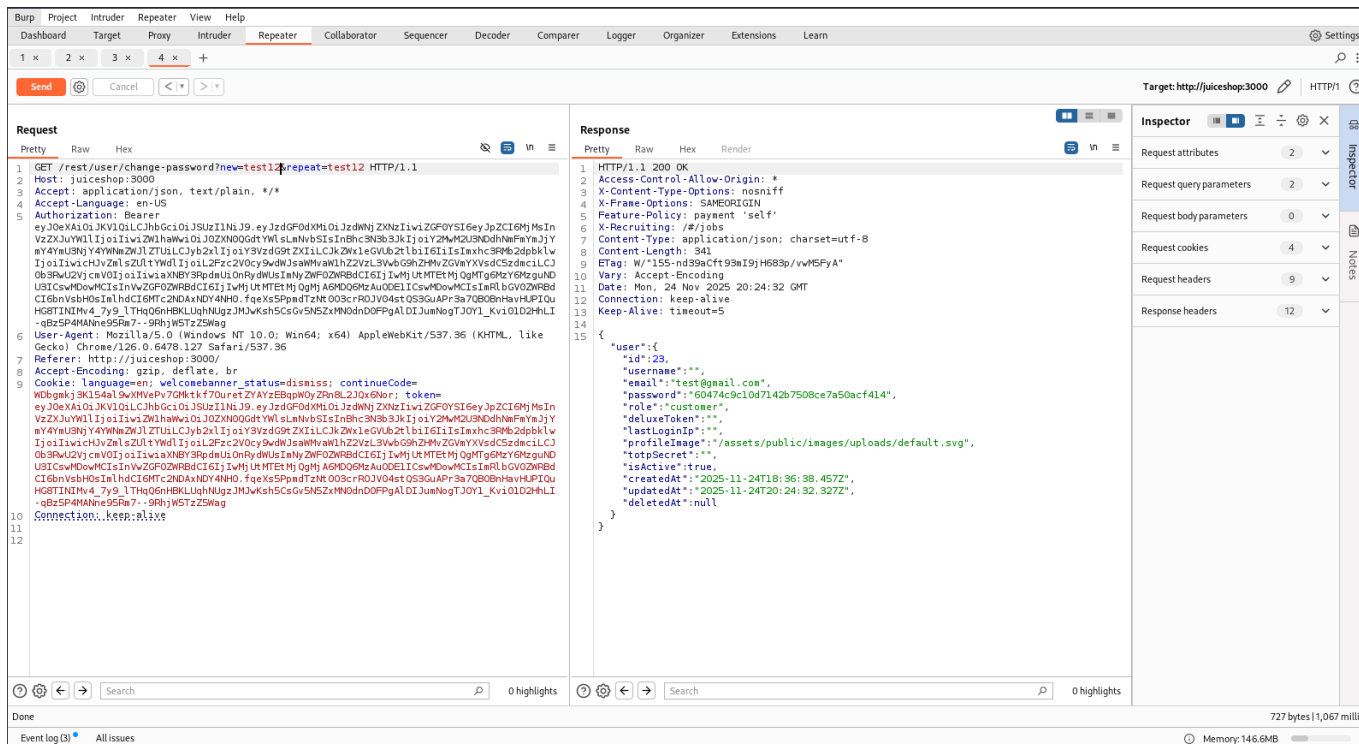
### Clasificación:

- **CWE:** CWE-306: Missing Authentication for Critical Function y CWE-862: Missing Authorization
- **OWASP Top 10:** A01:2021 - Broken Access Control y A07:2021 - Identification and Authentication Failures
- **CVSS v3.1:** 8.8 - High
- **Vector:** CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

### Cálculo CVSS:

- **AV:N** (Attack Vector: Network) - El ataque se ejecuta por HTTP.
- **AC:L** (Attack Complexity: Low) - Solo requiere enviar una solicitud manipulada.
- **PR:N** (Privileges Required: Low) - El atacante necesita un token JWT válido (rol básico).
- **UI:N** (User Interaction: None) - No requiere que la víctima haga clic o realice acciones.
- **C:H** (Confidentiality: High) - Compromiso total de la cuenta.
- **I:H** (Integrity: High) - Se modifica información sensible (la contraseña).
- **A:H** (Availability: High) - Puede bloquear al usuario legítimo al impedirle el acceso.

### Screenshots:



## Vulnerabilidad 5: Broken Access Control en carrito de compras

### Descripción Técnica:

El endpoint que permite obtener los productos que el usuario ha agregado al carrito `/rest/basket/:id` no realiza ninguna validación acerca del usuario que está realizando la solicitud y el carrito que está solicitando. Esto permite que cualquiera con un token de sesión válido pueda ver lo que otros usuarios están comprando.

### Pasos para Reproducir:

1. Autenticarse en Juice Shop como cualquier usuario (o interceptar su token).
2. Realizar una solicitud GET al endpoint `/rest/basket/:id`, sustituyendo `id` por un ID válido de otro usuario.
3. El servidor devolverá el contenido completo del carrito del usuario solicitado, sin verificar que el usuario autenticado sea el propietario.

### Payload Utilizado:

```
curl -X GET "http://localhost:3000/rest/basket/2" \
-H "Authorization: Bearer <TOKEN_VALIDO>"
```

### Response Obtenida:

```
{
 "status": "success",
 "data": {
 "id": 2,
 "coupon": null,
 "UserId": 2,
```

```

"createdAt": "2025-11-24T16:55:36.482Z",
"updatedAt": "2025-11-24T16:55:36.482Z",
"Products": [
 {
 "id": 4,
 "name": "Raspberry Juice (1000ml)",
 "description": "Made from blended Raspberry Pi, water and sugar.",
 "price": 4.99,
 "deluxePrice": 4.99,
 "image": "raspberry_juice.jpg",
 "createdAt": "2025-11-24T16:55:35.581Z",
 "updatedAt": "2025-11-24T16:55:35.581Z",
 "deletedAt": null,
 "BasketItem": {
 "ProductId": 4,
 "BasketId": 2,
 "id": 4,
 "quantity": 2,
 "createdAt": "2025-11-24T16:55:36.748Z",
 "updatedAt": "2025-11-24T16:55:36.748Z"
 }
 }
]
}

```

### Impacto:

- **Confidencialidad:** ● ALTO - El atacante puede acceder al carrito de cualquier usuario, revelando productos comprados cantidad, precios y timestamps.
- **Integridad:** ● BAJO - El exploit indicado es de solo lectura.
- **Disponibilidad:** ● BAJO - No es un ataque de DoS.

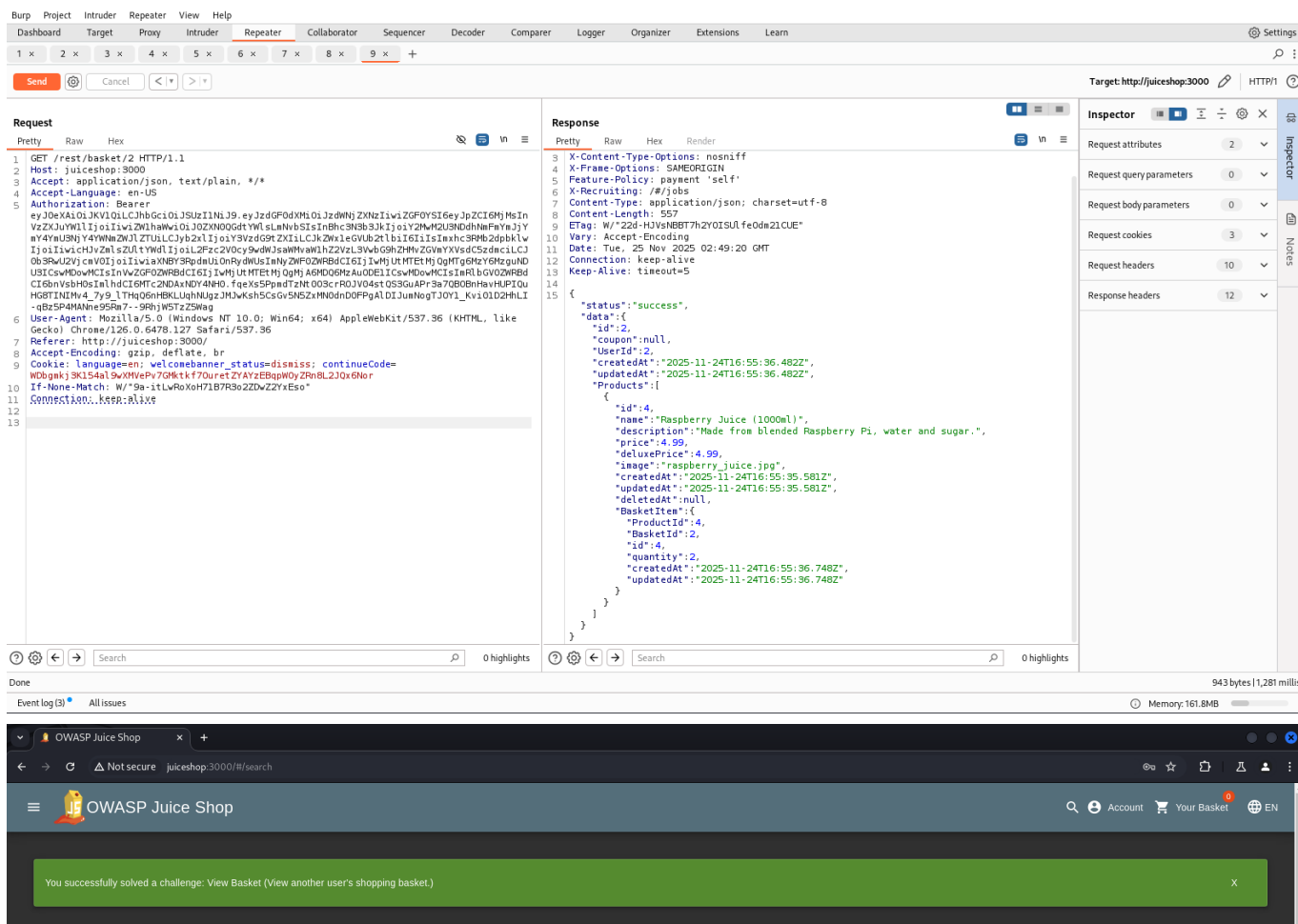
### Clasificación:

- **CWE:** CWE-639: Authorization Bypass Through User-Controlled Key y CWE-862: Missing Authorization
- **OWASP Top 10:** A01:2021 Broken Access Control
- **CVSS v3.1:** 4.3 - Medium
- **Vector:** CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

### Cálculo CVSS:

- **AV:N** (Attack Vector: Network) - El ataque se realiza vía HTTP.
- **AC:L** (Attack Complexity: Low) - Solo requiere cambiar el ID numérico en la URL.
- **PR:N** (Privileges Required: Low) - El atacante debe tener un token válido, pero cualquier usuario registrado puede explotar la falla.
- **UI:N** (User Interaction: None) - El ataque no requiere intervención del usuario víctima.
- **C:H** (Confidentiality: Low) - Se expone información sensible del carrito, pero no datos altamente críticos como contraseñas.
- **I:H** (Integrity: None) - El endpoint no modifica el carrito del usuario.
- **A:H** (Availability: None) - No afecta directamente la disponibilidad del sistema.

## Screenshots:



## Vulnerabilidad 6: Improper Input Validation en carrito de compras

Improper Input Validation ocurre cuando una aplicación no valida o no restringe adecuadamente los datos que recibe antes de procesarlos. En lugar de aplicar reglas de negocio adecuadas, el backend confía en que el cliente (frontend) hará esas validaciones.

En Juice Shop, a pesar de que la interfaz de usuario del carrito de compras impide que se ingresen cantidades negativas de productos, el endpoint `POST/PUT /api/BasketItems/` acepta sin problemas valores negativos en el campo "quantity". Esto permite manipular la lógica de cálculo del carrito y provocar montos totales negativos, que luego pueden convertirse en créditos indebidos para el usuario cuando completa la compra.

### Pasos para Reproducir:

1. Autenticarse en Juice Shop como cualquier usuario utilizando el navegador Proxy de Burp Suite.
2. Navegar al carrito de compras y, usando Burp Suite como proxy, interceptar la solicitud PUT que se envía al agregar un producto nuevo o modificar su cantidad.
3. Modificar el campo "quantity" de la solicitud en curso a un entero negativo, por ejemplo, -10, y reenviar la solicitud modificada.
4. Alternativamente, puede enviarse directamente una solicitud POST al endpoint `/api/BasketItems/` indicando el token de sesión válido, el ID del producto, el ID del carrito y la cantidad negativa.
5. Cuando el servidor reciba la solicitud, este no validará la cantidad especificada.
6. Si se continúa con el flujo de compra, el sistema considerará la cantidad negativa, pudiendo resultar en un precio total negativo y generando crédito a favor del usuario.

### Payload Utilizado:

```
curl -X POST "http://juiceshop:3000/api/BasketItems/" \
-H "Authorization: Bearer <TOKEN_VALIDO>" \
-H "Content-Type: application/json" \
-d '{
 "ProductId": 1,
 "BasketId": 6,
 "quantity": -10
}'
```

### Response Obtenida:

```
{
 "status": "success",
 "data": {
 "id": 11,
 "ProductId": 1,
 "BasketId": 6,
 "quantity": -10,
 "updatedAt": "2025-11-24T19:58:04.066Z",
 "createdAt": "2025-11-24T19:58:04.066Z"
 }
}
```

### Impacto:

- **Confidencialidad:** ● BAJO - No se expone información sensible de otros usuarios; el ataque se centra en manipular montos y lógica de negocio.
- **Integridad:** ● CRÍTICO - El atacante puede alterar la integridad de los datos financieros: carritos con montos negativos, generación de créditos indebidos en la cuenta del usuario y posible fraude al sistema de pagos o wallet interno.
- **Disponibilidad:** ● BAJO - No afecta directamente la disponibilidad del sistema, aunque un abuso masivo podría tener impacto económico para la organización.

### Clasificación:

- **CWE:** CWE-20 - Improper Input Validation y CWE-754 - Improper Check for Unusual or Exceptional Conditions
- **OWASP Top 10:** A04:2021 - Insecure Design
- **CVSS v3.1:** 6.5 - Medium
- **Vector:** CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

### Cálculo CVSS:

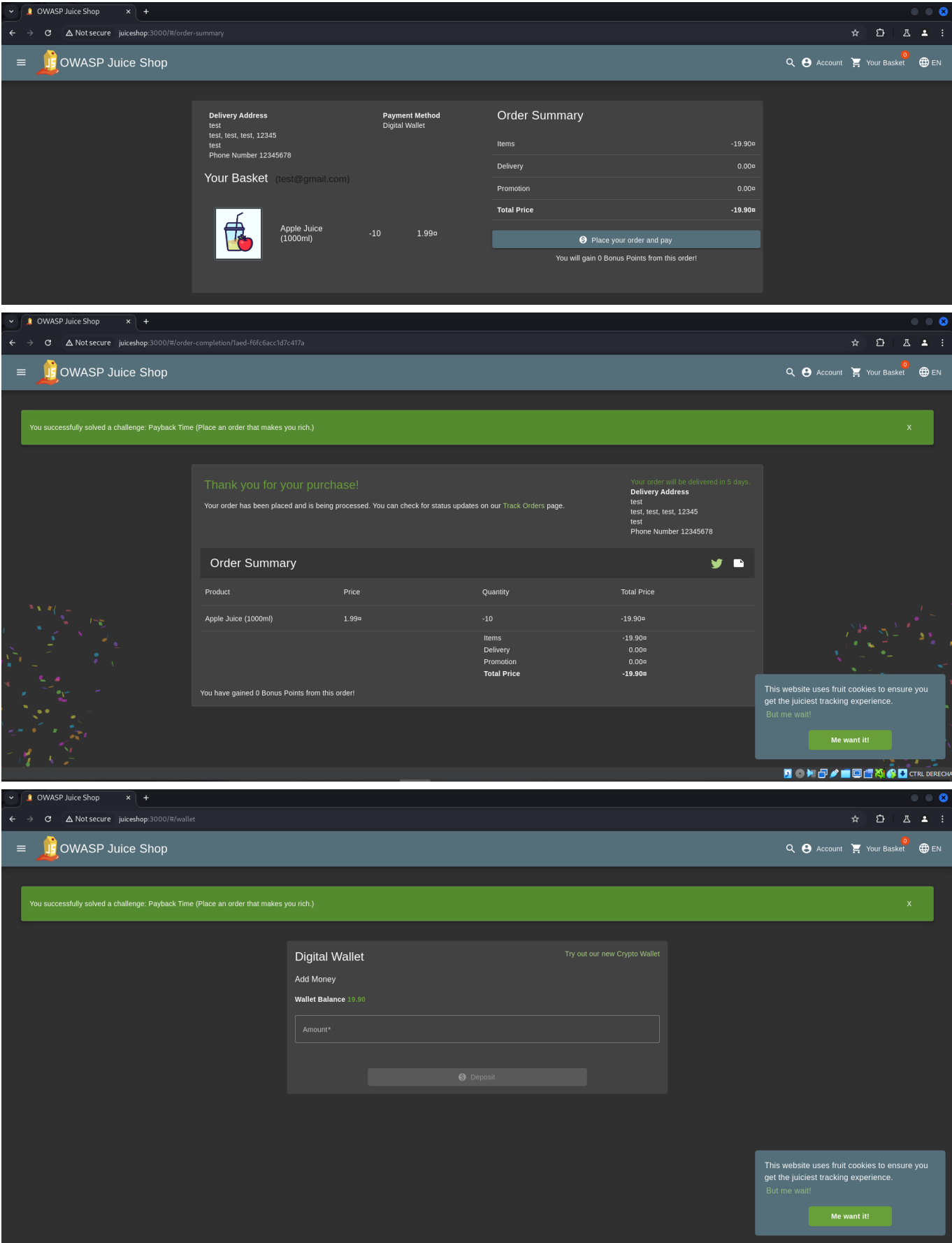
- **AV:N** (Attack Vector: Network) - El ataque se realiza enviando solicitudes HTTP contra la API.
- **AC:L** (Attack Complexity: Low) - Solo requiere modificar un valor numérico (quantity) en la petición.

- **PR:N** (Privileges Required: Low) - El atacante debe tener un token válido, pero cualquier usuario registrado puede explotar la falla.
- **UI:N** (User Interaction: None) - El atacante no depende de que una víctima haga algo; él mismo ejecuta el flujo.
- **C:H** (Confidentiality: None) - No se accede a datos confidenciales de otros usuarios.
- **I:H** (Integrity: High) - Se alteran reglas de negocio y montos económicos: se puede obtener dinero/crédito sin pagar.
- **A:H** (Availability: None) - No hay impacto directo en la disponibilidad del sistema.

## Screenshots:

The first screenshot shows the Burp Suite interface. The 'Repeater' tab is active, displaying a POST request to `http://juiceshop:3000/api/BasketItems/`. The request body is a JSON object: `{ "ProductId": 1, "BasketId": "6", "quantity": -10 }`. The response is a 200 OK status with a JSON body: `{ "status": "success", "data": { "id": 11, "ProductId": 1, "BasketId": "6", "quantity": -10, "updatedAt": "2025-11-24T19:58:04.066Z", "createdAt": "2025-11-24T19:58:04.066Z" } }`.

The second screenshot shows the OWASP Juice Shop web application. The 'Your Basket' section displays a list of items: 'Apple Juice (1000ml)' with a quantity of -10 and a price of 1.99. The total price is -19.90. A 'Checkout' button is visible at the bottom.



Verificación de Éxito

- ☒ 3 reglas de detección configuradas
- ☒ 4 vulnerabilidades explotadas
- ☒ Alertas generadas

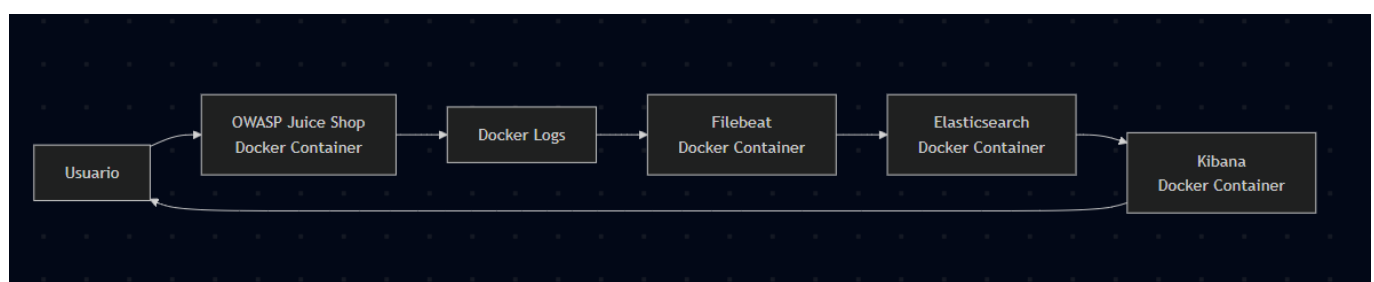
- ☒ Dashboard de detecciones creado
- ☒ 12 screenshots capturados
- ☒ Vulnerabilidades con CVSS calculado

## Conceptos Aprendidos

1. **Reglas de Detección:** [Explica]
2. **SQL Injection:** SQL Injection (SQLi) es una vulnerabilidad que ocurre cuando una aplicación inserta directamente datos proporcionados por el usuario dentro de una consulta SQL sin sanitización ni validación adecuada. Esto permite que un atacante inyecte código SQL malicioso, alterando la lógica original de la consulta.
3. **XSS:** Cross-Site Scripting (XSS) es una vulnerabilidad que permite a un atacante inyectar código JavaScript en una página vista por otros usuarios. Es posible cuando la aplicación refleja o almacena contenido del usuario sin escapar ni validar correctamente los caracteres especiales. En el XSS Reflejado, el payload vuelve inmediatamente en la respuesta. Se explota mediante enlaces maliciosos o parámetros manipulados.
4. **Improper Input Validation:** Ocurre cuando el backend no valida adecuadamente los datos, permitiendo valores absurdos, negativos, demasiado grandes, o formatos incorrectos.
5. **CVSS Scoring:** El Common Vulnerability Scoring System (CVSS) es un estándar internacional para medir la severidad de una vulnerabilidad. Evalúa varias métricas:
  - AV (Attack Vector): dónde puede explotarse (network, local, etc.).
  - AC (Attack Complexity): qué tan difícil es explotar.
  - PR (Privileges Required): si el atacante necesita autenticarse.
  - UI (User Interaction): si requiere acción de la víctima.
  - S (Scope): si se afecta otro componente distinto.
  - C (Confidentiality): impacto en confidencialidad.
  - I (Integrity): impacto en integridad.
  - A (Availability): impacto en disponibilidad.
6. **OWASP Top 10:** El OWASP Top 10 es una clasificación mantenida por OWASP que lista los diez riesgos más críticos de seguridad en aplicaciones web. Cada categoría agrupa vulnerabilidades comunes basadas en impacto, explotación y frecuencia en el mundo real.

## Análisis Técnico

### Arquitectura Completa del Sistema



**Componentes: Juice Shop** Es la aplicación vulnerable que genera el tráfico y los eventos de seguridad. Corre dentro de un contenedor de Docker y expone un puerto HTTP (3000) al que se conectan los usuarios. Cada petición, error y acción de la aplicación se traduce en logs que luego son recolectados por Filebeat.

**Docker Engine** Es la capa de orquestación que ejecuta y aísla los contenedores de Juice Shop, Elasticsearch, Kibana y Filebeat. Se encarga de crear las redes internas entre servicios, mapear los puertos hacia el host y almacenar los logs de cada contenedor para que puedan ser consumidos por otras herramientas.

**Filebeat** Es el agente de recolección de logs (log shipper). Se ejecuta también en un contenedor y está configurado para leer los logs de los contenedores de Docker (especialmente Juice Shop). Normaliza la información, agrega metadatos (como nombre del contenedor, imagen, host, etc.) y envía los eventos a Elasticsearch.

**Elasticsearch** Es el motor de búsqueda y almacenamiento de logs. Recibe los eventos enviados por Filebeat, los indexa y los hace consultables mediante su API REST. Permite almacenar grandes volúmenes de datos, realizar búsquedas avanzadas y servir como base para las visualizaciones y reglas de detección.

**Kibana** Es la interfaz visual del sistema. Se conecta a Elasticsearch para consultar los índices de logs, mostrar dashboards, crear visualizaciones, ejecutar búsquedas KQL y administrar las reglas de detección (Security → Alerts & Rules). Es el punto de contacto principal para el "Blue Team".

## Flujo de Datos Detallado

Usuario → Juice Shop → Docker Logs → Filebeat → Elasticsearch → Kibana

### Explicación paso a paso:

1. El usuario envía peticiones HTTP (navegar, iniciar sesión, buscar productos, explotar vulnerabilidades, etc.) al contenedor de Juice Shop. Cada acción genera respuestas y eventos internos (errores, warnings, access logs).
2. Juice Shop escribe sus logs en stdout/stderr dentro del contenedor. Docker Engine captura esa salida y la almacena como logs del contenedor, etiquetándolos con información como el nombre del contenedor, ID, timestamps, etc.
3. Filebeat está configurado para leer los logs de los contenedores de Docker. Cada línea de log se transforma en un evento estructurado (JSON) al que se le agregan metadatos (container.name, image.name, host, labels, etc.). Estos eventos se agrupan y se envían de forma continua hacia Elasticsearch.
4. Al recibir los eventos desde Filebeat, Elasticsearch los almacena en índices específicos (por ejemplo, filebeat-juice-shop-\*). Durante este proceso se analizan los campos, se aplican mappings y se optimiza la información para poder buscar por mensaje, contenedor, timestamp, IP, ruta, etc.
5. Kibana consulta los índices de Elasticsearch usando Data Views (por ejemplo, filebeat-\*). A partir de estos datos se construyen visualizaciones (gráficos, tablas, métricas) y dashboards. Además, las reglas de detección ejecutan consultas periódicas sobre los logs para buscar patrones de ataque (SQLi, XSS, fuerza bruta, scanners, etc.) y generar alertas cuando se cumplen las condiciones definidas.

6. Cuando una alerta se dispara, el analista puede usar Kibana para inspeccionar el evento, revisar el contexto (IP de origen, ruta atacada, payload, usuario afectado) y tomar decisiones: bloquear una IP, ajustar reglas, o recomendar cambios en la aplicación. De esta forma, lo que comenzó como simples logs termina siendo una herramienta de detección y respuesta ante incidentes.

## Conclusiones

### Logros Principales

1. Se implementó exitosamente un sistema completo de monitoreo y observabilidad utilizando la pila ELK (Elasticsearch, Logstash y Kibana), con Filebeat como agente de recolección.
2. Se analizaron y visualizaron los logs generados por Juice Shop en tiempo real, permitiendo identificar patrones, errores y actividad relevante.
3. Se configuraron reglas de detección en Kibana que permitieron identificar ataques comunes como SQL Injection, XSS y fuerza bruta.
4. Se desarrolló un proceso de Red Team que identificó y explotó cuatro vulnerabilidades reales en Juice Shop, cada una documentada con pasos, payloads, impacto y CVSS.
5. Se integraron los resultados del Red Team y Blue Team para validar el funcionamiento del sistema de detección y visibilizar ataques reales.

### Reflexión Personal

Trabajar en este proyecto fue interesante porque combinó varias áreas: despliegue de servicios con Docker, análisis de seguridad ofensiva (Red Team), configuración de detecciones (Blue Team) y visualización de datos con Kibana. Algo que destacó fue ver cómo un sistema de monitoreo cobra sentido cuando se analiza tráfico real generado por vulnerabilidades explotadas manualmente. No solo se trató de levantar contenedores, sino de entender cómo fluye la información desde la aplicación hasta Elasticsearch y cómo se transforma en insights útiles para seguridad.

Una de las partes más desafiantes fue la sección de detecciones, ya que crear reglas que no generen demasiados falsos positivos requiere realmente entender el comportamiento de la aplicación y del tráfico legítimo. Fue interesante ver que muchas reglas sencillas funcionan, pero para ambientes reales sería necesario un nivel mucho más complejo de normalización, correlación y filtrado. Aun así, este proyecto permite visualizar cómo funciona un SOC a pequeña escala y cómo un analista puede responder ante ataques reales.

Finalmente, este trabajo deja una buena base de conocimientos aplicables de inmediato: comprensión de logging centralizado, arquitectura básica de ELK, principios de diseño de reglas de detección, y experiencia práctica explotando vulnerabilidades web comunes. En un entorno profesional, este tipo de habilidades son esenciales tanto para desarrolladores que desean construir aplicaciones más seguras como para equipos de seguridad que necesitan monitorear la actividad en tiempo real.

### Aplicaciones Prácticas

**En el mundo real, este sistema se podría usar para:**

1. Empresas con múltiples servicios distribuidos pueden unificar registros en una sola plataforma para facilitar auditorías, troubleshooting, seguimiento de errores y análisis de rendimiento. Esto reduce drásticamente el tiempo de respuesta frente a fallas operativas.
2. Con reglas como las creadas para SQL Injection, XSS y fuerza bruta, un SOC puede identificar intentos de intrusión en tiempo real. Implementar dashboards y alertas permite detectar patrones sospechosos antes de que se conviertan en incidentes mayores.
3. Los logs históricos almacenados en Elasticsearch permiten reconstruir lo ocurrido durante un ataque: rutas accedidas, payloads utilizados, usuarios comprometidos y origen del tráfico. Esto facilita la respuesta a incidentes y fortalece controles futuros.
4. El proceso de Red Team aplicado en Juice Shop es equivalente al que realizaría un equipo interno para evaluar la robustez de un sistema. Usar ELK permite ver cómo reaccionan los sistemas de detección y qué brechas aún existen.
5. Industrias reguladas (finanzas, salud, telecomunicaciones) requieren mantener registros detallados de eventos y accesos. Un sistema ELK bien configurado ayuda a cumplir estándares como ISO 27001, PCI-DSS, GDPR o HIPAA.
6. Además de seguridad, ELK puede integrarse con métricas, trazas y logs para monitorear la salud general de una aplicación. Esto permite identificar cuellos de botella, tiempos de respuesta lentos o servicios que fallan con frecuencia.

## Habilidades Desarrolladas

- ☒ Administración de contenedores Docker
- ☒ Configuración de sistemas de logging
- ☒ Análisis de logs de seguridad
- ☒ Creación de visualizaciones de datos
- ☒ Detección de amenazas
- ☒ Explotación de vulnerabilidades (ético)
- ☒ Documentación técnica
- ☒ Troubleshooting

## Anexos

### Anexo A: Reglas de Detección (JSON)

```
{
 "id": "e50ef170-ca33-11f0-9a1c-8bff4fefb87e",
 "updated_at": "2025-11-25T19:21:09.312Z",
 "updated_by": "elastic",
 "created_at": "2025-11-25T19:21:09.312Z",
 "created_by": "elastic",
 "name": "SQL Injection Detection - Nginx",
 "tags": ["SQL Injection", "Web Attack", "OWASP"],
 "interval": "1m",
 "enabled": true,
 "revision": 0,
 "description": "Detect a patrones de SQL Injection en request_uri de nginx",
 "risk_score": 80,
 "severity": "high",
 "output_index": "",
 "author": [],
 "false_positives": [],
 "from": "now-2m",
 "rule_id": "detect-sqli-002",
 "max_signals": 100,
 "risk_score_mapping": [],
 "severity_mapping": [],
 "threat": [],
 "to": "now",
 "references": [],
 "version": 1,
 "exceptions_list": []
}
```

```
[],"immutable":false,"related_integrations":[],"required_fields":
[,"setup":"","type":"query","language":"kuery","index":["filebeat-nginx-access-
*"],"query":"request_uri: (*OR* or *UNION* or *SELECT* or *INSERT* or *DROP* or *-
* or *%27* or *1=1*)","actions":[]}]
```

```
{"id":"d65252d0-ca4c-11f0-88b4-171c166119f3","updated_at":"2025-11-
25T22:19:42.025Z","updated_by":"elastic","created_at":"2025-11-
25T22:19:42.025Z","created_by":"elastic","name":"Security Scanner
Detection","tags":["Scanner","Reconnaissance","Automated
Attack"],"interval":"1m","enabled":true,"revision":0,"description":"Detecta
tráfico de herramientas de escaneo (sqlmap, nmap, burp, nikto,
etc)","risk_score":60,"severity":"medium","output_index":"","author":
[,"false_positives":[],"from":"now-2m","rule_id":"detect-scanner-
001","max_signals":100,"risk_score_mapping":[],"severity_mapping":[],"threat":
[,"to":"now","references":[],"version":1,"exceptions_list":
[,"immutable":false,"related_integrations":[],"required_fields":
[,"setup":"","type":"query","language":"kuery","index":["filebeat-nginx-access-
*"],"query":"http_user_agent: (*sqlmap* or *nmap* or *burp* or *nikto* or *python-
requests* or *Nuclei* or *masscan* or *ZAP* or *Acunetix* or *Nessus*)","actions":
[]}]
```

```
{"id":"e73a92f0-ca52-11f0-88b4-171c166119f3","updated_at":"2025-11-
25T23:03:07.725Z","updated_by":"elastic","created_at":"2025-11-
25T23:03:07.725Z","created_by":"elastic","name":"Command Injection
Detection","tags":["Command Injection","Web
Attack","RCE"],"interval":"1m","enabled":true,"revision":0,"description":"Detecta
intentos de command injection en
URLs","risk_score":90,"severity":"critical","output_index":"","author":
[,"false_positives":[],"from":"now-2m","rule_id":"detect-cmdinj-
001","max_signals":100,"risk_score_mapping":[],"severity_mapping":[],"threat":
[,"to":"now","references":[],"version":1,"exceptions_list":
[,"immutable":false,"related_integrations":[],"required_fields":
[,"setup":"","type":"query","language":"kuery","index":["filebeat-nginx-access-
*"],"query":"request_uri.keyword: *%3B* or request_uri.keyword: *%7C* or
request_uri.keyword: *%60*","actions":[]}]
```

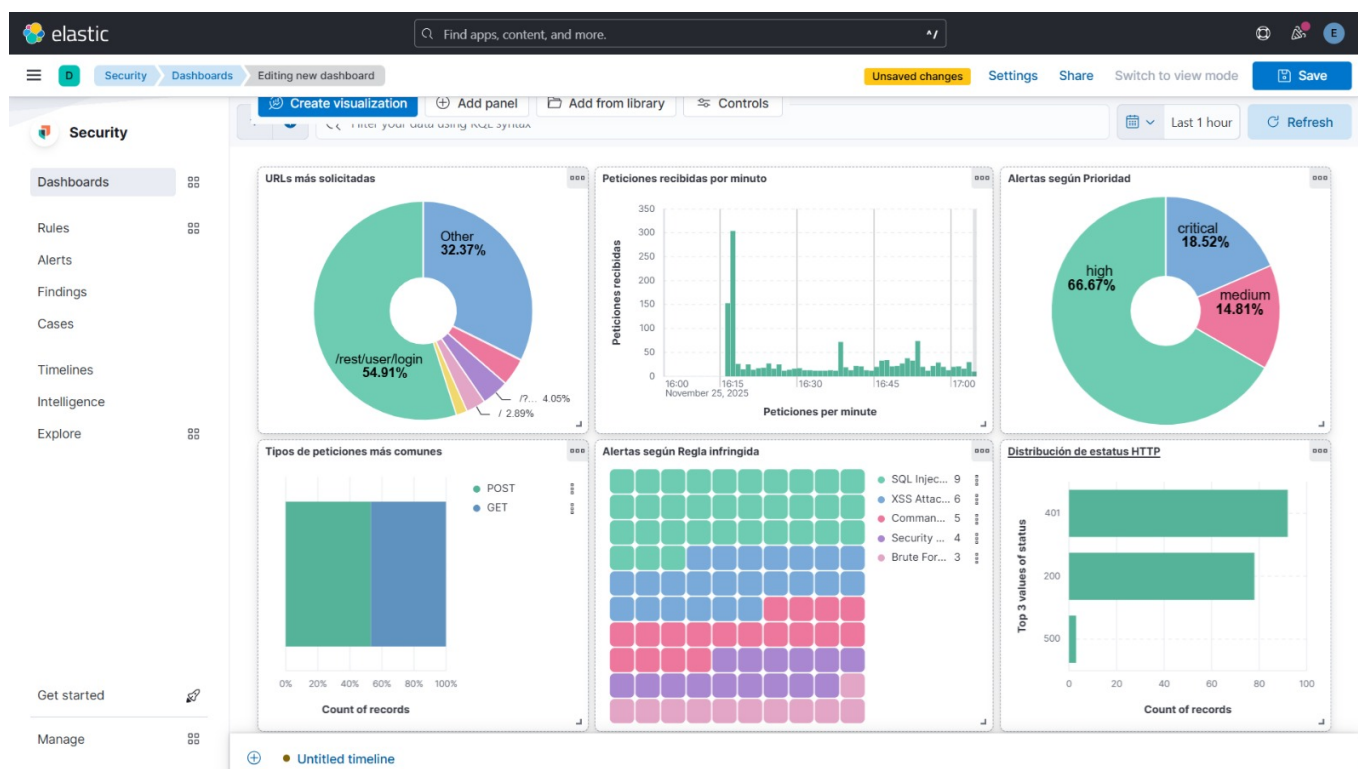
```
{"id":"b58e9460-ca50-11f0-88b4-171c166119f3","updated_at":"2025-11-
25T22:47:24.337Z","updated_by":"elastic","created_at":"2025-11-
25T22:47:24.337Z","created_by":"elastic","name":"Brute Force Login
Detection","tags":["Brute
Force","Authentication","OWASP"],"interval":"1m","enabled":true,"revision":0,"desc
ription":"Detecta múltiples intentos fallidos de login en Juice
Shop","risk_score":70,"severity":"high","output_index":"","author":
[,"false_positives":[],"from":"now-2m","rule_id":"detect-bruteforce-
001","max_signals":100,"risk_score_mapping":[],"severity_mapping":[],"threat":
[,"to":"now","references":[],"version":1,"exceptions_list":
[,"immutable":false,"related_integrations":[],"required_fields":
[,"setup":"","type":"threshold","language":"kuery","index":["filebeat-nginx-
access-*"],"query":"request_uri: \"/rest/user/login\" and status:
401","threshold":{"field":["remote_addr.keyword"],"value":5},"actions":[]}]
```

```
{"id":"cc8ca520-ca4c-11f0-88b4-171c166119f3","updated_at":"2025-11-
25T22:19:24.803Z","updated_by":"elastic","created_at":"2025-11-
25T22:19:24.803Z","created_by":"elastic","name":"XSS Attack Detection","tags":
["XSS","Web Attack","OWASP Top
```

```
10"],"interval":"1m","enabled":true,"revision":0,"description":"Detecta payloads sospechosos de XSS en URLs y mensajes","risk_score":75,"severity":"high","output_index":"","author":[],"false_positives":[],"from":"now-2m","rule_id":"detect-xss-001","max_signals":100,"risk_score_mapping":[],"severity_mapping":[],"threat":[],"to":"now","references":[],"version":1,"exceptions_list":[],"immutable":false,"related_integrations":[],"required_fields":[],"setup":"","type":"query","language":"kuery","index":["filebeat-nginx-access-*","filebeat-juice-shop-*"],"query":"request_uri:(*%3Cscript* or *%3Cimg* or *javascript* or *onerror* or *alert*)","actions":[]}]

{"exported_count":5,"exported_rules_count":5,"missing_rules":[],"missing_rules_count":0,"exported_exception_list_count":0,"exported_exception_list_item_count":0,"missing_exception_list_item_count":0,"missing_exception_list_items":[],"missing_exception_lists":[],"missing_exception_lists_count":0,"exported_action_connector_count":0,"missing_action_connection_count":0,"missing_action_connections":[],"excluded_action_connection_count":0,"excluded_action_connections":[]}
```

## Anexo B: Dashboard Export



```
{"attributes":{"allowNoIndex":true,"fieldAttrs":{"},"fieldFormatMap":{"},"fields":[""],"name":".alerts-security.alerts-default,apm-*transaction*,auditbeat-*,endgame-*,filebeat-*,logs-*,packetbeat-*,traces-apm*,winlogbeat-*,-*elastic-cloud-logs-*","runtimeFieldMap":{"},"sourceFilters":[""],"timeFieldName":"@timestamp","title":".alerts-security.alerts-default,apm-*transaction*,auditbeat-*,endgame-*,filebeat-*,logs-*,packetbeat-*,traces-apm*,winlogbeat-*,-*elastic-cloud-logs-*","typeMeta":{"}}},"coreMigrationVersion":"8.8.0","created_at":"2025-11-25T19:21:30.208Z","id":"security-solution-default","managed":false,"references":
```

```
[{"type":"index-pattern","typeMigrationVersion":"8.0.0","updated_at":"2025-11-25T19:21:30.208Z","version":"WzUsM10="}]
```

```
{
 "attributes": {
 "color": "#D36086",
 "description": "",
 "name": "Security Solution",
 "coreMigrationVersion": "8.8.0",
 "created_at": "2025-11-25T23:44:46.632Z",
 "id": "security-solution-default",
 "managed": true,
 "references": [
 {
 "type": "tag",
 "typeMigrationVersion": "8.0.0",
 "updated_at": "2025-11-25T23:44:46.632Z",
 "version": "WzIyODksM10="
 }
]
 }
}
```

```
{
 "attributes": {
 "description": "",
 "kibanaSavedObjectMeta": {
 "searchSourceJSON": {
 "\query\":"query\":"\",
 "\language\":"kuery\",
 "\filter\":"\",
 "\optionsJSON\":"\"
 }
 },
 "optionsJSON": {
 "\useMargins\":"true\",
 "\syncColors\":"false\",
 "\syncCursor\":"true\",
 "\syncTooltips\":"false\",
 "\hidePanelTitles\":"false\",
 "panelsJSON": [
 {
 "\type\":"lens\",
 "\gridData\":"\"x\":"0\",
 "\y\":"0\",
 "\w\":"15\",
 "\h\":"11\",
 "\i\":"fade6d8d-3fa5-444e-81ef-3cc525eb1375\",
 "\panelIndex\":"fade6d8d-3fa5-444e-81ef-3cc525eb1375\",
 "\embeddableConfig\":"\"attributes\":"\"title\":"\",
 "\description\":"\",
 "\visualizationType\":"lensPie\",
 "\type\":"lens\",
 "\references\":"\"type\":"index-pattern\",
 "\id\":"security-solution-default\",
 "\name\":"indexpattern-datasource-layer-fe51ff47-2e31-4a6b-860b-f68a87533ea0\",
 "\state\":"\"visualization\":"\"shape\":"donut\",
 "\layers\":"\"layerId\":"fe51ff47-2e31-4a6b-860b-f68a87533ea0\",
 "\primaryGroups\":"\"5a1f3769-5d6e-4d61-aca8-40fe99cfc69\",
 "\metrics\":"\"8f3aa464-04c5-4313-9d5d-0d95adba671f\",
 "\numberDisplay\":"percent\",
 "\categoryDisplay\":"default\",
 "\legendDisplay\":"default\",
 "\nestedLegend\":"false\",
 "\layerType\":"data\",
 "\query\":"\"query\":"\",
 "\language\":"kuery\",
 "\filters\":"\",
 "\datasourceStates\":"\"formBased\":"\"layers\":"fe51ff47-2e31-4a6b-860b-f68a87533ea0\":{
 \"columns\":"\"5a1f3769-5d6e-4d61-aca8-40fe99cfc69\":{
 \"label\":"Top 5 values of request_uri.keyword\",
 \"dataType\":"string\",
 \"operationType\":"terms\",
 \"scale\":"ordinal\",
 \"sourceField\":"request_uri.keyword\",
 \"isBucketed\":"true\",
 \"params\":"\"size\":"5\",
 \"orderBy\":"\"type\":"column\",
 \"columnId\":"8f3aa464-04c5-4313-9d5d-0d95adba671f\",
 \"orderDirection\":"desc\",
 \"otherBucket\":"true\",
 \"missingBucket\":"false\",
 \"parentFormat\":"id\":"terms\",
 \"include\":"\",
 \"exclude\":"\",
 \"includeIsRegex\":"false\",
 \"excludeIsRegex\":"false\",
 \"accuracyMode\":"true\",
 \"8f3aa464-04c5-4313-9d5d-0d95adba671f\":{
 \"label\":"Count of records\",
 \"dataType\":"number\",
 \"operationType\":"count\",
 \"isBucketed\":"false\",
 \"scale\":"ratio\",
 \"sourceField\":"__records__\",
 \"params\":"\"emptyAsNull\":"true\",
 \"columnOrder\":"\"5a1f3769-5d6e-4d61-aca8-40fe99cfc69\",
 \"8f3aa464-04c5-4313-9d5d-0d95adba671f\",
 \"sampling\":"1\",
 \"ignoreGlobalFilters\":"false\",
 \"incompleteColumns\":"\",
 \"indexpattern\":"\"layers\":"\",
 \"textBased\":"\"layers\":"\",
 \"internalReferences\":"\",
 \"adHocDataViews\":"\",
 \"hidePanelTitles\":"false\",
 \"enhancements\":"\",
 \"title\":"URLs más solicitadas\",
 \"type\":"lens\",
 \"gridData\":"\"x\":"15\",
 \"y\":"0\",
 \"w\":"18\",
 \"h\":"11\",
 \"i\":"299ce26e-261f-4a43-ac5c-0bab8574140a\",
 \"panelIndex\":"299ce26e-261f-4a43-ac5c-0bab8574140a\",
 \"embeddableConfig\":"\"attributes\":"\"title\":"\",
 \"description\":"\",
 \"visualizationType\":"lensXY\",
 \"type\":"lens\",
 \"references\":"\"type\":"index-pattern\",
 \"id\":"security-solution-default\",
 \"name\":"indexpattern-datasource-layer-d8b93e33-c856-415c-8332-95ad1f99dd37\",
 \"state\":"\"visualization\":"\"title\":"Empty XY chart\",
 \"legend\":"\"isVisible\":"true\",
 \"position\":"right\",
 \"valueLabels\":"hide\",
 \"preferredSe
```

```
riesType\":"bar_stacked\","layers\":[{"layerId\":"d8b93e33-c856-415c-8332-95ad1f99dd37\","accessors\":["18bb7842-70fa-4d31-bbdc-8bbecebc01c1\"],"position\":"top\","seriesType\":"bar_stacked\","showGridline\":false,"layerType\":"data\","xAccessor\":"c47df7ee-81a5-4abf-9173-663cbb5cae6\"}]},{"query\":"query\":"\","language\":"kuery\"},"filters\":[],"datasourceStates\":{"formBased\":{"layers\":{"d8b93e33-c856-415c-8332-95ad1f99dd37\":{"columns\":{"c47df7ee-81a5-4abf-9173-663cbb5cae6\":{"label\":"Peticiones\","dataType\":"date\","operationType\":"date_histogram\","sourceField\":"@timestamp\","isBucketed\":true,"scale\":"interval\","params\":{"interval\":"auto\","includeEmptyRows\":true,"dropPartials\":false},"customLabel\":true},"18bb7842-70fa-4d31-bbdc-8bbecebc01c1\":{"label\":"Peticiones recibidas\","dataType\":"number\","operationType\":"count\","isBucketed\":false,"scale\":"ratio\","sourceField\":"__records__\","params\":{"emptyAsNull\":true},"customLabel\":true}}},"columnOrder\":["c47df7ee-81a5-4abf-9173-663cbb5cae6","18bb7842-70fa-4d31-bbdc-8bbecebc01c1\"],"sampling\":1,"ignoreGlobalFilters\":false,"incompleteColumns\":{}}},"indexpattern\":{"layers\":{}},"textBased\":{"layers\":{}}},"internalReferences\":[],"adHocDataViews\":{}}},"hidePanelTitles\":false,"enhancements\":{}},"title\":"Peticiones recibidas por minuto\","type\":"lens\","gridData\":{"x\":33,"y\":0,"w\":15,"h\":11,"i\":"6b9dc65f-8341-4039-8469-cce9d70e5ff1\"},"panelIndex\":"6b9dc65f-8341-4039-8469-cce9d70e5ff1\","embeddableConfig\":{"attributes\":{"title\":"\","description\":"\","visualizationType\":"lensPie\","type\":"lens\","references\":[{"type\":"index-pattern\","id\":"security-solution-default\","name\":"indexpattern-datasource-layer-8ce26ed2-8c8d-44b7-955c-0f1f5e774bdd\"],"state\":{"visualization\":{"shape\":"donut\","layers\":[{"layerId\":"8ce26ed2-8c8d-44b7-955c-0f1f5e774bdd\","primaryGroups\":["437f758d-1d3c-45ca-991b-b3d7b145cf7e\"],"metrics\":["7d8076ed-1133-46f3-b1c1-93876851b692\"],"numberDisplay\":"percent\","categoryDisplay\":"default\","legendDisplay\":"default\","nestedLegend\":false,"layerType\":"data\"}]},"query\":"query\":"\","language\":"kuery\"},"filters\":[],"datasourceStates\":{"formBased\":{"layers\":{"8ce26ed2-8c8d-44b7-955c-0f1f5e774bdd\":{"columns\":{"437f758d-1d3c-45ca-991b-b3d7b145cf7e\":{"label\":"Top 5 values of kibana.alert.severity\","dataType\":"string\","operationType\":"terms\","scale\":"ordinal\","sourceField\":"kibana.alert.severity\","isBucketed\":true,"params\":{"size\":5,"orderBy\":{"type\":"column\","columnId\":"7d8076ed-1133-46f3-b1c1-93876851b692\"},"orderDirection\":"desc\","otherBucket\":true,"missingBucket\":false,"parentFormat\":{"id\":"terms\"},"include\":[],"exclude\":[],"includeIsRegex\":false,"excludeIsRegex\":false},"7d8076ed-1133-46f3-b1c1-93876851b692\":{"label\":"Count of records\","dataType\":"number\","operationType\":"count\","isBucketed\":false,"scale\":"ratio\","sourceField\":"__records__\","params\":{"emptyAsNull\":true}}},"columnOrder\":["437f758d-1d3c-45ca-991b-b3d7b145cf7e","7d8076ed-1133-46f3-b1c1-93876851b692\"],"sampling\":1,"ignoreGlobalFilters\":false,"incompleteColumns\":{}}},"indexpattern\":{"layers\":{}},"textBased\":{"layers\":{}}},"internalReferences\":[],"adHocDataViews\":{}}},"hidePanelTitles\":false,"enhancements\":{}},"title\":"Alertas según Prioridad\","type\":"lens\","gridData\":{"x\":0,"y\":11,"w\":15,"h\":12,"i\":"32d6cea5-c727-4075-a0ba-09a6b592ad65\"},"panelIndex\":"32d6cea5-c727-4075-a0ba-
```

```

09a6b592ad65\", \"embeddableConfig\": { \"attributes\":
{ \"title\": \"\", \"description\": \"\", \"visualizationType\": \"lensXY\", \"type\": \"lens\", \"references\": [{ \"type\": \"index-pattern\", \"id\": \"security-solution-default\", \"name\": \"indexpattern-datasource-layer-5f881761-0e89-4d36-be42-01f72e2adc70\" }], \"state\": { \"visualization\": { \"legend\": { \"isVisible\": true, \"position\": \"right\", \"valueLabels\": \"hide\", \"fittingFunction\": \"None\", \"axisTitlesVisibilitySettings\": { \"x\": true, \"yLeft\": true, \"yRight\": true }, \"tickLabelsVisibilitySettings\": { \"x\": true, \"yLeft\": true, \"yRight\": true }, \"labelsOrientation\": { \"x\": 0, \"yLeft\": 0, \"yRight\": 0 }, \"gridlinesVisibilitySettings\": { \"x\": true, \"yLeft\": true, \"yRight\": true }, \"preferredSeriesType\": \"bar_horizontal_percentage_stacked\", \"layers\": [{ \"layerId\": \"5f881761-0e89-4d36-be42-01f72e2adc70\", \"accessors\": [\"27fb1f26-647b-4b81-a722-0cef863d1cb4\"], \"position\": \"top\", \"seriesType\": \"bar_horizontal_percentage_stacked\", \"showGridlines\": false, \"layerType\": \"data\", \"splitAccessor\": \"34bdea76-ab84-4879-a9aa-a75eb2d35dfc\" }] }, \"query\": { \"query\": \"\", \"language\": \"kuery\", \"filters\": [], \"datasourceStates\": { \"formBased\": { \"layers\": { \"5f881761-0e89-4d36-be42-01f72e2adc70\": { \"columns\": { \"34bdea76-ab84-4879-a9aa-a75eb2d35dfc\": { \"label\": \"Top 5 values of request_method.keyword\", \"dataType\": \"string\", \"operationType\": \"terms\", \"scale\": \"ordinal\", \"sourceField\": \"request_method.keyword\", \"isBucketed\": true, \"params\": { \"size\": 5, \"orderBy\": { \"type\": \"column\", \"columnId\": \"27fb1f26-647b-4b81-a722-0cef863d1cb4\" }, \"orderDirection\": \"desc\", \"otherBucket\": true, \"missingBucket\": false, \"parentFormat\": { \"id\": \"terms\" }, \"include\": [], \"exclude\": [], \"includeIsRegex\": false, \"excludeIsRegex\": false } }, \"27fb1f26-647b-4b81-a722-0cef863d1cb4\": { \"label\": \"Count of records\", \"dataType\": \"number\", \"operationType\": \"count\", \"isBucketed\": false, \"scale\": \"ratio\", \"sourceField\": \"__records__\", \"params\": { \"emptyAsNull\": true } } }, \"columnOrder\": [\"34bdea76-ab84-4879-a9aa-a75eb2d35dfc\", \"27fb1f26-647b-4b81-a722-0cef863d1cb4\"], \"sampling\": 1, \"ignoreGlobalFilters\": false, \"incompleteColumns\": { } }, \"indexpattern\": { \"layers\": { }, \"textBased\": { \"layers\": { } }, \"internalReferences\": [], \"adHocDataViews\": { } }, \"hidePanelTitles\": false, \"enhancements\": { }, \"title\": \"Tipos de peticiones más comunes\", { \"type\": \"lens\", \"gridData\": { \"x\": 15, \"y\": 11, \"w\": 18, \"h\": 12, \"i\": \"bb12a0be-6203-4699-aeaf-674336b757d0\" }, \"panelIndex\": \"bb12a0be-6203-4699-aeaf-674336b757d0\", \"embeddableConfig\": { \"attributes\": { \"title\": \"\", \"description\": \"\", \"visualizationType\": \"lensPie\", \"type\": \"lens\", \"references\": [{ \"type\": \"index-pattern\", \"id\": \"security-solution-default\", \"name\": \"indexpattern-datasource-layer-ef04990e-ef03-46f7-a767-5c30add25b73\" }], \"state\": { \"visualization\": { \"shape\": \"waffle\", \"layers\": [{ \"layerId\": \"ef04990e-ef03-46f7-a767-5c30add25b73\", \"primaryGroups\": [\"38d6d73c-6ba1-45b5-afef-b1d841541e2e\"], \"metrics\": [\"f22e147e-a770-490d-bf68-2886fb53183a\"], \"numberDisplay\": \"percent\", \"categoryDisplay\": \"default\", \"legendDisplay\": \"default\", \"nestedLegend\": false, \"layerType\": \"data\" }] }, \"query\": { \"query\": \"\", \"language\": \"kuery\", \"filters\": [], \"datasourceStates\": { \"formBased\": { \"layers\": { \"ef04990e-ef03-46f7-a767-5c30add25b73\": { \"columns\": { \"38d6d73c-6ba1-45b5-afef-b1d841541e2e\": { \"label\": \"Top 5 values of kibana.alert.rule.name\", \"dataType\": \"string\", \"operationType\": \"terms\", \"scale\": \"ordinal\", \"sourceField\": \"kibana.alert.rule.name\", \"isBucketed\": true, \"params\": { \"size\": 5, \"orderBy\": { \"type\": \"column\", \"columnId\": \"f22e147e-a770-490d-bf68-

```

```

2886fb53183a\"},\"orderDirection\": \"desc\", \"otherBucket\": true, \"missingBucket\":
: false, \"parentFormat\": {\"id\": \"terms\"}, \"include\": [], \"exclude\":
[], \"includeIsRegex\": false, \"excludeIsRegex\": false}}, \"f22e147e-a770-490d-bf68-
2886fb53183a\": {\"label\": \"Count of
records\", \"dataType\": \"number\", \"operationType\": \"count\", \"isBucketed\": false
, \"scale\": \"ratio\", \"sourceField\": \"__records__\", \"params\":
{\"emptyAsNull\": true}}, \"columnOrder\": [\"38d6d73c-6ba1-45b5-afef-
b1d841541e2e\", \"f22e147e-a770-490d-bf68-
2886fb53183a\"], \"sampling\": 1, \"ignoreGlobalFilters\": false, \"incompleteColumns\":
: {}}, \"indexpattern\": {\"layers\": {}}, \"textBased\": {\"layers\":
{}}, \"internalReferences\": [], \"adHocDataViews\":
{}}, \"hidePanelTitles\": false, \"enhancements\": {}, \"title\": \"Alertas según
Regla infringida\", {\"type\": \"lens\", \"gridData\":
{\"x\": 33, \"y\": 11, \"w\": 15, \"h\": 12, \"i\": \"13dc8ed8-6bbc-402a-a79a-
e5cbad160644\"}, \"panelIndex\": \"13dc8ed8-6bbc-402a-a79a-
e5cbad160644\", \"embeddableConfig\": {\"attributes\":
{\"title\": \"\", \"description\": \"\", \"visualizationType\": \"lensXY\", \"type\": \"le
ns\", \"references\": [{\"type\": \"index-pattern\", \"id\": \"security-solution-
default\", \"name\": \"indexpattern-datasource-layer-0e411c42-4db7-4ac9-a4dc-
c6914f5f3191\"}], \"state\": {\"visualization\": {\"legend\":
{\"isVisible\": true, \"position\": \"right\", \"valueLabels\": \"hide\", \"fittingFunc
tion\": \"None\", \"axisTitlesVisibilitySettings\":
{\"x\": true, \"yLeft\": true, \"yRight\": true}, \"tickLabelsVisibilitySettings\":
{\"x\": true, \"yLeft\": true, \"yRight\": true}, \"labelsOrientation\":
{\"x\": 0, \"yLeft\": 0, \"yRight\": 0}, \"gridlinesVisibilitySettings\":
{\"x\": true, \"yLeft\": true, \"yRight\": true}, \"preferredSeriesType\": \"bar_horizont
al_stacked\", \"layers\": [{\"layerId\": \"0e411c42-4db7-4ac9-a4dc-
c6914f5f3191\", \"seriesType\": \"bar_horizontal_stacked\", \"xAccessor\": \"0e21b61c-
3c77-4b69-a005-8a65a5c630d1\", \"accessors\": [\"ae4af829-4563-4c3e-880c-
93542163e1e0\"], \"layerType\": \"data\"}]}, \"query\":
{\"query\": \"\", \"language\": \"kquery\", \"filters\": [], \"datasourceStates\":
{\"formBased\": {\"layers\": {\"0e411c42-4db7-4ac9-a4dc-c6914f5f3191\": {\"columns\":
{\"0e21b61c-3c77-4b69-a005-8a65a5c630d1\": {\"label\": \"Top 3 values of
status\", \"dataType\": \"number\", \"operationType\": \"terms\", \"scale\": \"ordinal\"
, \"sourceField\": \"status\", \"isBucketed\": true, \"params\":
{\"size\": 3, \"orderBy\": {\"type\": \"column\", \"columnId\": \"ae4af829-4563-4c3e-
880c-
93542163e1e0\"}, \"orderDirection\": \"desc\", \"otherBucket\": true, \"missingBucket\":
: false, \"parentFormat\": {\"id\": \"terms\"}, \"include\": [], \"exclude\":
[], \"includeIsRegex\": false, \"excludeIsRegex\": false}}, \"ae4af829-4563-4c3e-880c-
93542163e1e0\": {\"label\": \"Count of
records\", \"dataType\": \"number\", \"operationType\": \"count\", \"isBucketed\": false
, \"scale\": \"ratio\", \"sourceField\": \"__records__\", \"params\":
{\"emptyAsNull\": true}}, \"columnOrder\": [\"0e21b61c-3c77-4b69-a005-
8a65a5c630d1\", \"ae4af829-4563-4c3e-880c-
93542163e1e0\"], \"sampling\": 1, \"ignoreGlobalFilters\": false, \"incompleteColumns\":
: {}}, \"indexpattern\": {\"layers\": {}}, \"textBased\": {\"layers\":
{}}, \"internalReferences\": [], \"adHocDataViews\":
{}}, \"hidePanelTitles\": false, \"enhancements\": {}, \"title\": \"Distribución de
estatus HTTP\"}}], \"timeRestore\": false, \"title\": \"Dashboard Proyecto 2
DSS\", \"version\": 1}, \"coreMigrationVersion\": \"8.8.0\", \"created_at\": \"2025-11-
25T23:47:10.123Z\", \"id\": \"0f02d7b0-ca59-11f0-88b4-
171c166119f3\", \"managed\": false, \"references\": [{\"id\": \"security-solution-
default\", \"name\": \"fade6d8d-3fa5-444e-81ef-3cc525eb1375:indexpattern-datasource-

```

```
layer-fe51ff47-2e31-4a6b-860b-f68a87533ea0", "type": "index-pattern"},
{"id": "security-solution-default", "name": "299ce26e-261f-4a43-ac5c-0bab8574140a:indexpattern-datasource-layer-d8b93e33-c856-415c-8332-95ad1f99dd37", "type": "index-pattern"}, {"id": "security-solution-default", "name": "6b9dc65f-8341-4039-8469-cce9d70e5ff1:indexpattern-datasource-layer-8ce26ed2-8c8d-44b7-955c-0f1f5e774bdd", "type": "index-pattern"}, {"id": "security-solution-default", "name": "32d6cea5-c727-4075-a0ba-09a6b592ad65:indexpattern-datasource-layer-5f881761-0e89-4d36-be42-01f72e2adc70", "type": "index-pattern"}, {"id": "security-solution-default", "name": "bb12a0be-6203-4699-aeaf-674336b757d0:indexpattern-datasource-layer-ef04990e-ef03-46f7-a767-5c30add25b73", "type": "index-pattern"}, {"id": "security-solution-default", "name": "13dc8ed8-6bbc-402a-a79a-e5cbad160644:indexpattern-datasource-layer-0e411c42-4db7-4ac9-a4dc-c6914f5f3191", "type": "index-pattern"}, {"id": "security-solution-default", "name": "tag-ref-security-solution-default", "type": "tag"}], "type": "dashboard", "typeMigrationVersion": "8.9.0", "updated_at": "2025-11-25T23:47:10.123Z", "version": "WzE10SwzXQ==" }

{"excludedObjects":
[], "excludedObjectsCount": 0, "exportedCount": 3, "missingRefCount": 0, "missingReferences": []}
```

## Estadísticas del Proyecto

- **Total de Screenshots:** 58 (mínimo 42)
- **Total de Comandos Ejecutados:** 31
- **Total de Vulnerabilidades Explotadas:** 4
- **Total de Reglas de Detección:** 3
- **Total de Visualizaciones Creadas:** 3
- **Total de Dashboards Creados:** 2
- **Tiempo Total Invertido:** 6.16 horas

## Checklist de Entrega

### Documentación

- ☒ Reporte completo
- ☒ Todos los pasos documentados
- ☒ Screenshots de calidad
- ☒ Comandos con outputs
- ☒ Problemas explicados

### Red Team

- ☒ 4 vulnerabilidades explotadas
- ☒ Cada una con PoC completo
- ☒ CVSS calculado
- ☒ OWASP Top 10 clasificación

## Blue Team

- ☒ 3 reglas configuradas
- ☒ Alertas funcionando
- ☒ Dashboard de detecciones
- ☒ Informe de respuesta

## Archivos

- ☒ reporte-final.pdf o .md
- ☒ screenshots/ organizado
- ☒ reglas-deteccion.json
- ☒ dashboard-export.ndjson

---

## Fin del Reporte

**Fecha de Entrega:** 25 de noviembre de 2025

**Firma:** Pablo Zamora, Diego Aquino y Erick Guerra